Module 03 · 집계 기반 침해분석 · 대응

로그만으로 찾고 ,
규칙으로 막는다

PURPLE 15 라운드 중 로그로 재현 가능한 13 라운드를 집계 중심으로 .

라운드당 90 일 240 만 건 · 외부 IP 100 만 + · 정상 99.9% · 실제 공격 없음

앞 모듈 (집계 기초) 의 여섯 집계를 섞어 침해를 단계별로 찾는다

이 트랙은 이렇게 생겼다

실제 공격은 하지 않는다 . 라운드별 생성기가 정상 99.9% 에 공격 로그를 섞어 Wazuh 인덱서에 적재한다 . 외부 IP 는 전부 가상이다 .

라운드마다 다섯 가지	하는 일
생성기 (rNN_*.py)	정상 99.9% + 공격 로그를 인덱서에 적재
정답 키 (answers/)	인덱서 없이 계산한 집계 결과 — 숫자를 맞춰 본다
실습 (lab_rNN.yaml)	미션 8 개 — 명령은 한 줄씩 , 예상 출력 포함
강의 (lecture_rNN.md)	질문 · 집계 문항 · 규칙 팩 · 대응
규칙 팩 (rules/rNN/)	Suricata · ModSecurity · Wazuh · Sigma · osquery · Sysmon

데이터는 이렇게 생겼다

항목	값
규모	라운드당 약 240만 건 (90일, 최대 365일)
외부 IP	서로 다른 100만+ (전부 가상)
정상 비율	99.84 ~ 99.99% — 공격은 바늘, 정상은 건초더미
엔드포인트 IP	포트가 아니라 시스템마다 가상 IP: juice .81 · dvwa .82 · neobank .83 · govportal .84 · mediforum .85 · admin .86 · ai .87 · webmail .26 (198.51.100.x)
인덱스	purple-rNN · 패턴 purple-* · 시간 필드 timestamp · 기준일 2026-11-01

시스템마다 자기 IP를 줘야 '목적지 IP 집계'가 현실처럼 읽힌다 (서버가 먼저 말을 거는 비콘을 목적지로 잡는다).

시간 프로파일

공격자의 시간은 실제 집계에서 가져왔다

실제 장기 집계표 (출발지 13,543 개) 의 활동 일수 · 주말 비율 · 업무시간 외 비율 · 시작 시각 분포를 프로파일로 만들어 재방문을 흉내 낸다 .

유형	비율	모습
1 회성	37%	하루 들르고 사라진다
재방문	55%	몇 주에 걸쳐 띄엄띄엄
상주	8%	석 달 내내 거의 매일

그래서 ' 하루만 보면 ' 공격이 안 보인다 . 90 일 전체를 집계해야 재방문 · 장기 비콘 · 분산 정찰이 드러난다 .

지도

13 개 라운드 지도 — 공격 단계대로 (1/2)

정찰부터 유출·AI 공격까지, 공격의 단계(kill chain)를 따라간다. 각 라운드는 '그 단계를 집계로 어떻게 찾나'를 다룬다.

라운드	단계
R01	가시성 베이스라인
R02	정찰
R03	웹 취약점 공격
R04	지속화 · 웹셸
R05	권한상승 · 방어 회피
R06	자격증명 공격

13 개 라운드 지도 — 공격 단계대로 (2/2)

라운드	단계
R07	횡적 이동
R08	C2· 유출
R09	중간 종합 — 석 달 체인
R10	임팩트 — 랜섬 · 장애
R12	AI 서비스 공격
R13	AI 레드팀 — 기계 속도
R15	최종 — 혼합 체인 · 미끼

미션 구성

라운드 하나 = 미션 여덟 개

#	미션
1	적재 + 정상의 모양
2~4	탐지 집계 ①②③
5	모니터 (Alerting)
6	Suricata · ModSec · osquery
7	Wazuh 상관 + Sigma
8	대응 + 라운드 카드

집계 미션마다 : DSL 읽기 → curl 로 직접 질의 → ask 로 정답 키와 비교 → Visualize 로 같은 그림 . 기준일 2026-11-01 이면 숫자가 정답 키와 같다 .

R01 · 가시성 베이스라인

가시성 베이스라인 — 정상의 모양과 서버발 비콘

정상의 모양을 집계로 재고, 그 위에서 서버발 비콘 하나를 찾는다

총 2,444,723 건 · 공격 2,262 건 · 정상 (배경 포함) 99.907%

R01 시나리오 — 무엇이 일어났나

R01 운영체제 수립 + 가시성 베이스라인 — 정상의 모양을 집계로 재고, 그 위에서 튀는 것을 본다.

Red — 공격 (로그로만 재현, 실제 공격 없음)

- juiceshop 서버 (10.20.40.81) 에 심긴 Caldera sandcat 이 C2 로 30~60 초마다 POST /beat.
- Discovery 명령 (whoami·pwd·ls·ifconfig·which) 은 로그가 남지 않는다 (가시성 0).

Blue — 집계로 찾기

- 엔드포인트별 정상 분포 → 서버발 외부 목적지 집계 → 시간 규칙성 → 모니터.

R01 데이터 — 정상의 모양부터 (1/2)

총 2,444,723 건 · 공격 2,262 건 · 정상 (배경 포함) 99.907%

기간	기본 90 일 (D-90 ~ D-1). 기준일 2026-11-01 이면 정답 키와 숫자가 같다
인덱스	`purple-r01` · 인덱스 패턴 `purple-*` · 시간 필드 `timestamp`

엔드포인트 — 시스템마다 가상 IP

시스템	IP
juice.kt66.lab	`198.51.100.81`
dvwa.kt66.lab	`198.51.100.82`
neobank.kt66.lab	`198.51.100.83`

R01 데이터 — 정상의 모양부터 (2/2)

시스템	IP
govportal.kt66.lab	198.51.100.84
mediforum.kt66.lab	198.51.100.85
admin.kt66.lab	198.51.100.86
ai.kt66.lab	198.51.100.87
webmail.kt66.lab	198.51.100.26
bastion	10.20.30.201
KT66-WIN-01	10.20.70.10

R01 Q1 집계 쿼리 — 이벤트 출처 (에이전트) 별 분포 — 정상의 모양 ①

```
POST purple-r01/_search
{
  "size": 0,
  "aggs": {
    "by_agent": {
      "terms": {
        "field": "agent.name",
        "size": 15
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter).
size:0 = 원문 로그는 안 가져오고 집계 숫자만

R01 · Terms(버킷)

R01 Q1 결과 읽기 — 이벤트 출처 (에이전트) 별 분포 — 정상의 모양 ①

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수
juiceshop	646923
govportal	544452
neobank	431298
mediforum	306478
aicompanion	291603
ips	48743
dns	42087
mail	35166

왜 이걸 보나 — 어느 센서가 얼마나 말하는지부터 본다 — 정상의 크기를 모르면 이상의 크기도 모른다 .

Visualize 로 같은 표 Split rows: Terms agent.name size 15

R01 Q2 집계 쿼리 — 웹 엔드포인트별 요청 수와 서로 다른 방문 IP 수 — 정상의 모양 ②

```
POST purple-r01/_search
{
  "size": 0,
  "query": {
    "term": {
      "decoder.name": "web-accesslog"
    }
  },
  "aggs": {
    "by_vhost": {
      "terms": {
        "field": "data.vhost",
        "size": 10
      },
      "aggs": {
        "ips": {
          "cardinality": {
            "field": "data.srcip",
            "precision_threshold": 40000
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R01 · Terms(버킷) · Cardinality(고유 수)

R01 Q2 결과 읽기 — 웹 엔드포인트별 요청 수와 서로 다른 방문 IP 수 — 정상의 모양 ②

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	서로 다른 IP 수
juice.kt66.lab	601306	315452
govportal.kt66.lab	505865	263357
neobank.kt66.lab	400135	212532
mediforum.kt66.lab	282181	150659
ai.kt66.lab	218010	119769
webmail.kt66.lab	24870	4020
admin.kt66.lab	515	15

왜 이걸 보나 — 웹 7 개 vhost 는 포트가 아니라 각자의 가상 IP(198.51.100.x) 를 가진다 . 요청 수와 방문 IP 수의 비율이 서비스의 성격이다 .

Visualize 로 같은 표 `Split rows: Terms data.vhost size 10 → Metric: Unique Count data.srcip`

R01 Q3 집계 쿼리 — 주별 이벤트 추이 (7 일 버킷 , KST) — 기간 전체의 모양

```
POST purple-r01/_search
{
  "size": 0,
  "aggs": {
    "per_week": {
      "date_histogram": {
        "field": "timestamp",
        "fixed_interval": "7d",
        "time_zone": "+09:00",
        "format": "yyyy-MM-dd",
        "min_doc_count": 1
      }
    }
  }
}
```

집계 기법 : Date Histogram(시간) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R01 Q3 결과 읽기 — 주별 이벤트 추이 (7 일 버킷 , KST) — 기간 전체의 모양

결과 (kt66 실제 적재 · 기준일 2026-11-01)

key_as_string	건수
2026-07-30	80707
2026-08-06	191114
2026-08-13	190769
2026-08-20	191084
2026-08-27	187822
2026-09-03	189122
2026-09-10	192501
2026-09-17	191836

왜 이걸 보나 — 90 일 전체를 7 일 버킷으로 접으면 계절성 · 공백 · 급증이 한 화면에 보인다 .

Visualize 로 같은 표 `Split rows: Date Histogram timestamp 간격 7d`

R01 Q4 집계 쿼리 — 서버존 (10.20.40.x) 에서 밖으로 나간 연결 — 목적지 상위

```
POST purple-r01/_search
{
  "size": 0,
  "query": {
    "prefix": {
      "data.src_ip": "10.20.40."
    }
  },
  "aggs": {
    "by_dst": {
      "terms": {
        "field": "data.dest_ip",
        "size": 8
      },
      "aggs": {
        "srcs": {
          "cardinality": {
            "field": "data.src_ip"
          }
        },
        "days": {
          "date_histogram": {
            "field": "timestamp",
            "fixed_interval": "1d",
            "time_zone": "+09:00",
            "min_doc_count": 1
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · Date Histogram(시간) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R01 Q4 결과 읽기 — 서버존 (10.20.40.x) 에서 밖으로 나간 연결 — 목적지 상위

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	서로 다른 출발지 수	활동 일수
53.81.8.74	2262	1	75
128.46.18.8	1544	6	90
50.43.18.30	1519	6	90
177.26.187.82	1510	6	90
173.33.200.126	1496	6	90
94.192.235.148	1464	6	90
180.185.226.103	1420	6	90

왜 이걸 보나 — 서버는 먼저 말을 걸지 않는다 — 서버존발 외부 연결 중 '출발지 1 곳 × 매일' 은 사람이 아니라 프로그램이다 .

Visualize 로 같은 표

```
Split rows: Terms data.dest_ip size 8 → Metric: Unique Count data.src_ip
→ Split rows: Date Histogram timestamp  간격 1d
```

R01 Q5 집계 쿼리 — 출발지 1 곳뿐인 목적지 (53.81.8.74) — 일별 요청 수 (가장 많은 날 순)

```
POST purple-r01/_search
{
  "size": 0,
  "query": {
    "term": {
      "data.dest_ip": "53.81.8.74"
    }
  },
  "aggs": {
    "per_day": {
      "date_histogram": {
        "field": "timestamp",
        "fixed_interval": "1d",
        "time_zone": "+09:00",
        "format": "yyyy-MM-dd",
        "min_doc_count": 1,
        "order": {
          "_count": "desc"
        }
      }
    }
  }
}
```

집계 기법 : Date Histogram(시간) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R01 Q5 결과 읽기 — 출발지 1 곳뿐인 목적지 (53.81.8.74) — 일별 요청 수 (가장 많은 날 순)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

key_as_string	건수
2026-10-30	503
2026-08-23	25
2026-08-28	25
2026-08-31	25
2026-09-03	25
2026-09-05	25

왜 이걸 보나 — 같은 목적지의 일별 건수 — 평소 24 건 (1 시간 주기) 인데 하루만 수백 건이면 운영자가 붙은 날이다 .

Visualize 로 같은 표 `Split rows: Date Histogram timestamp 간격 1d`

R01 Q6 집계 쿼리 — 같은 목적지 요청의 경로 · 메서드 ·UA 조합

```
POST purple-r01/_search
{
  "size": 0,
  "query": {
    "term": {
      "data.dest_ip": "53.81.8.74"
    }
  },
  "aggs": {
    "by_url": {
      "terms": {
        "field": "data.http.url",
        "size": 5
      },
      "aggs": {
        "m": {
          "terms": {
            "field": "data.http
              .http_user_agent",
            "size": 3
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter).
size:0 = 원문 로그는 안 가져오고 집계 숫자만

R01 Q6 결과 읽기 — 같은 목적지 요청의 경로 · 메서드 ·UA 조합

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
/beat	Go-http-client/1.1	2261
/file/download	curl/7.81.0	1

왜 이걸 보나 — 경로 · 메서드 ·UA 조합이 하나뿐이면 사람이 아니라 에이전트다 .

Visualize 로 같은 표

```
Split rows: Terms data.http.url size 5 →
Split rows: Terms data.http.http_user_agent
size 3
```

R01 Q7 집계 쿼리 — 지금 경보 (rule.level ≥ 7) 는 무엇을 보고 있나 — 상위 5

```
POST purple-r01/_search
{
  "size": 0,
  "query": {
    "range": {
      "rule.level": {
        "gte": 7
      }
    }
  },
  "aggs": {
    "by_rule": {
      "terms": {
        "field": "rule.description",
        "size": 5
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R01 Q7 결과 읽기 — 지금 경보 (rule.level ≥ 7) 는 무엇을 보고 있나 — 상위 5

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수
Integrity checksum changed.	7095
sshd: brute force trying to get access to the system. Non existent user.	736
File deleted.	540

왜 이걸 보나 — 지금의 경보는 무엇을 보고 있나 — 비콘은 경보 상위에 없다 (가시성 ✔ 탐지 ✘).

Visualize 로 같은 표

Split rows: Terms rule.description size 5

R01 모니터 — 집계를 경보로

경보는 '한 줄'이 아니라 '조건을 넘는 집계 결과'로 울린다 — bucket_selector 로 거른 뒤 OpenSearch Alerting 모니터로 자동화한다.

모니터

서버존발 외부 목적지 중 출발지가 1 곳이고 500 회 이상인 곳 (비콘 후보) — 트리거 `ctx.results[0].aggregations.by_dst.buckets.size() > 0`

지금 걸리는 대상

값	건수	서로 다른 출발지 수
53.81.8.74	2262	1

트리거

```
ctx.results[0].aggregations.by_dst.buckets.size() > 0
```

R01 규칙 팩 — 같은 판단을 자동화

집계로 '찾은' 판단을 서명 (Suricata·ModSecurity)· 상관 (Wazuh)·Sigma·osquery 규칙으로 바꿔 자동 탐지한다 .

도구	ID	내용
Suricata	9601001	PURPLE R01 server-zone HTTP POST to non-80 port (beacon candidate)
Suricata	9601002	PURPLE R01 Caldera sandcat beacon URI /beat
Wazuh	190101 (L3)	PURPLE R01: 서버존 $(src_ip) → $(dest_ip):$(dest_port) POST $(http.url)
Wazuh	190102 (L10)	PURPLE R01: 같은 서버가 같은 외부 목적지로 하루 20 회 이상 POST — 비콘 의심 $(src_ip) → $(dest_ip) [빈도 20/86400s]
Sigma	단건	PURPLE R01 Server Zone POST to Non-standard Port
Sigma	상관	PURPLE R01 Beacon - 20 POSTs per day to same destination
osquery	purple_r01_outbound_nonstd	R01: 외부 비표준 포트로 연결된 프로세스 (비콘 후보)
osquery	purple_r01_tmp_exec	R01: /tmp·/dev/shm 에서 실행 중인 프로세스 (sandcat 기본 드롭 위치)
Sysmon	NetworkConnect	rules/r01/sysmon.xml

R01 대응 — 그래서 무엇을 하나

대응

비콘 목적지는 kt66-fw 의 egress 블록리스트에 , 감염 서버는 격리 후보로 . 경보 (190102) 는 purple-ar 가 기록만 한다 .

생각해 볼 것

- 서명 (한 줄)· 상관 (분 ~ 일)· 집계 (전체 기간) 중 이 라운드의 공격을 처음 드러낸 것은 무엇인가 ?
- 정상 99.9% 안에서 임계값을 어디에 두면 오탐이 0 이 되는가 ? (미션 2~4 의 분포로 근거를 댄다)
- 공격자가 기간을 두 배로 늘리면 (--days 180) 어떤 집계가 약해지고 어떤 집계가 강해지는가 ?

R01 한 장 정리

결정적 집계	서버존발 외부 목적지 × 출발지 수 × 활동 일수
찾은 것	출발지 1 곳 · 75 일 · 2,262 회 — 평소 하루 25 회 , 하루만 503 회
규칙	Suricata POST /beat · Wazuh 하루 20 회 같은 목적지 · 모니터 500 회 +

분산 · 장기 공격은 서명 · 상관에서 0 건이 정상 — 그래서 집계가 먼저다 .

R02 · 정찰

정찰 · 탐색 — 넓게 훑는 IP 찾기

많이 온 IP 가 아니라 '넓게 훑은' IP — 고유 URL 수 · 고유 포트 수 · 활동 일수로 정찰을 가른다

총 2,441,323 건 · 공격 1,676 건 · 정상 (배경 포함) 99.931%

R02 시나리오 — 무엇이 일어났나

R02 정찰 · 탐색 — 많이 온 IP 가 아니라 '이상하게 넓게 훑은' IP 를 찾는다.

Red — 공격 (로그로만 재현, 실제 공격 없음)

- A: 외부 포트 스캔 — 공개 VIP 8 개 × 상위 100 포트 (FW DROP + IDS)
- B: 웹 콘텐츠 탐색 — govportal·mediforum 에 경로 사전 대입 (평범한 브라우저 UA 로 위장)
- C: 분산 저속 정찰 — 300 개 IP 가 neobank API 의 숨은 경로 2 개를 1~2 번씩

Blue — 집계로 찾기

- 요청량 상위 (정상 대량 이용자) → 404 상위 → IP 별 고유 URL → 경로별 고유 IP → 포트 다양성

R02 데이터 — 정상의 모양부터 (1/2)

총 2,441,323 건 · 공격 1,676 건 · 정상 (배경 포함) 99.931%

기간	기본 90 일 (D-90 ~ D-1). 기준일 2026-11-01 이면 정답 키와 숫자가 같다
인덱스	`purple-r02` · 인덱스 패턴 `purple-*` · 시간 필드 `timestamp`

엔드포인트 — 시스템마다 가상 IP

시스템	IP
juice.kt66.lab	`198.51.100.81`
dvwa.kt66.lab	`198.51.100.82`
neobank.kt66.lab	`198.51.100.83`

R02 데이터 — 정상의 모양부터 (2/2)

시스템	IP
govportal.kt66.lab	198.51.100.84
mediforum.kt66.lab	198.51.100.85
admin.kt66.lab	198.51.100.86
ai.kt66.lab	198.51.100.87
webmail.kt66.lab	198.51.100.26
bastion	10.20.30.201
KT66-WIN-01	10.20.70.10

R02 Q1 집계 쿼리 — 웹 요청 수 상위 10 IP — 많이 온 IP 는 누구인가

```
POST purple-r02/_search
{
  "size": 0,
  "query": {
    "term": {
      "decoder.name": "web-accesslog"
    }
  },
  "aggs": {
    "by_ip": {
      "terms": {
        "field": "data.srcip",
        "size": 10
      },
      "aggs": {
        "ua": {
          "terms": {
            "field": "data.user_agent",
            "size": 1
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R02 Q1 결과 읽기 — 웹 요청 수 상위 10 IP — 많이 온 IP 는 누구인가 (1/7)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
196.112.185.106	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36	9859

R02 Q1 결과 읽기 — 웹 요청 수 상위 10 IP — 많이 온 IP 는 누구인가 (2/7)

구분	값	건수
36.7.157.250	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36	4737

R02 Q1 결과 읽기 — 웹 요청 수 상위 10 IP — 많이 온 IP 는 누구인가 (3/7)

구분	값	건수
187.107.249.198	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36	3088

R02 Q1 결과 읽기 — 웹 요청 수 상위 10 IP — 많이 온 IP 는 누구인가 (4/7)

구분	값	건수
215.193.57.7	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36	2271
7.136.73.90	Pingdom.com_bot_version_1.4_(http://www.pingdom.c	6267

R02 Q1 결과 읽기 — 웹 요청 수 상위 10 IP — 많이 온 IP 는 누구인가 (5/7)

구분	값	건수
198.200.89.99	Pingdom.com_bot_version_1.4_(http://www.pingdom.com/)	6258
163.218.135.80	Mozilla/5.0+(compatible; UptimeRobot/2.0; http://www.uptimerobot.com/)	6162

R02 Q1 결과 읽기 — 웹 요청 수 상위 10 IP — 많이 온 IP 는 누구인가 (6/7)

구분	값	건수
163.4.251.34	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36	1810

R02 Q1 결과 읽기 — 웹 요청 수 상위 10 IP — 많이 온 IP 는 누구인가 (7/7)

왜 이걸 보나 — 요청 수 1 위는 대개 정상 대량 사용자 (NAT· 봇) 다 — '많이' 는 정찰의 신호가 아니다 .

Visualize 로 같은 표

```
Split rows: Terms data.srcip size 10 → Split rows: Terms data.user_agent size 1
```

R02 Q2 집계 쿼리 — 404 응답을 가장 많이 받은 IP 상위 5

```
POST purple-r02/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        },
        {
          "term": {
            "data.id": "404"
          }
        }
      ]
    }
  },
  "aggs": {
    "by_ip": {
      "terms": {
        "field": "data.srcip",
        "size": 5
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter).
size:0 = 원문 로그는 안 가져오고 집계 숫자만

R02 Q2 결과 읽기 — 404 응답을 가장 많이 받은 IP 상위 5

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수
221.49.17.120	341
196.112.185.106	119
15.80.134.2	69
150.173.171.62	62
135.89.117.84	61

왜 이걸 보나 — 404 는 '없는 것을 찾았다'는 뜻 — 404 상위가 첫 번째 거름망이다.

Visualize 로 같은 표

```
Split rows: Terms data.srcip size 5
```

R02 Q3 집계 쿼리 — 404 IP 별 서로 다른 URL 수·vhost 수 (고유 URL 순)

```
POST purple-r02/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        },
        {
          "term": {
            "data.id": "404"
          }
        }
      ]
    }
  },
  "aggs": {
    "by_ip": {
      "terms": {
        "field": "data.srcip",
        "size": 5,
        "order": {
          "urls": "desc"
        }
      },
      "aggs": {
        "urls": {
          "cardinality": {
            "field": "data.url"
          }
        },
        "hosts": {
          "cardinality": {
            "field": "data.vhost"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R02 Q3 결과 읽기 — 404 IP 별 서로 다른 URL 수·vhost 수 (고유 URL 순)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	고유 URL 수	고유 vhost 수
221.49.17.120	341	241	2
196.112.185.106	119	102	4
15.80.134.2	69	69	3
150.173.171.62	62	62	3
135.89.117.84	61	61	3

왜 이걸 보나 — 고유 URL 수가 수백인 IP 는 사람이 아니다 . 404 건수보다 cardinality 가 정찰을 가른다 .

Visualize 로 같은 표

Split rows: Terms data.srcip size 5 · 정렬 urls desc → Metric: Unique Count data.url → Metric: Unique Count data.vhost

R02 Q4 집계 쿼리 — neobank API(/api/) 404 — 경로별 서로 다른 IP 수

```
POST purple-r02/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        },
        {
          "term": {
            "data.vhost": "neobank.kt66.lab"
          }
        },
        {
          "term": {
            "data.id": "404"
          }
        },
        {
          "prefix": {
            "data.url": "/api/"
          }
        }
      ]
    }
  },
  "aggs": {
    "by_url": {
      "terms": {
        "field": "data.url",
        "size": 5,
        "order": {
          "ips": "desc"
        }
      },
      "aggs": {
        "ips": {
          "cardinality": {
            "field": "data.srcip"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R02 Q4 결과 읽기 — neobank API(/api/) 404 — 경로별 서로 다른 IP 수

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	서로 다른 IP 수
/api/v1/admin/users	226	226
/api/v1/accounts/export?format=csv	218	218
/api/history?page=15	49	49
/api/history?page=2	45	45
/api/history?page=16	44	44

왜 이걸 보나 — 같은 숨은 경로를 서로 다른 IP 수백 곳이 한두 번씩 — IP 별 집계로는 안 보이고 경로별 집계로만 보인다 .

Visualize 로 같은 표

Split rows: Terms data.url size 5 · 정렬 ips desc →
Metric: Unique Count data.srcip

R02 Q5 집계 쿼리 — 숨은 API 경로를 두드린 IP 들의 국가 분포

```
POST purple-r02/_search
{
  "size": 0,
  "query": {
    "terms": {
      "data.url": [
        "/api/v1/admin/users",
        "/api/v1/accounts/export?format=csv"
      ]
    }
  },
  "aggs": {
    "by_cc": {
      "terms": {
        "field": "GeoLocation.country_name",
        "size": 6
      },
      "aggs": {
        "ips": {
          "cardinality": {
            "field": "data.srcip"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R02 Q5 결과 읽기 — 숨은 API 경로를 두드린 IP 들의 국가 분포

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	서로 다른 IP 수
China	142	92
India	113	77
Vietnam	102	70
Brazil	87	61

왜 이걸 보나 — 분산 정찰 IP 의 국가 분포 — 한 나라 집중이면 같은 인프라일 가능성 .

Visualize 로 같은 표

```
Split rows: Terms GeoLocation.country_name size 6
→ Metric: Unique Count data.srcip
```

R02 Q6 집계 쿼리 — 방화벽 차단 (DROP) — IP 별 서로 다른 포트 · 목적지 수 · 활동 일수

```
POST purple-r02/_search
{
  "size": 0,
  "query": {
    "term": {
      "decoder.name": "kt66-nft"
    }
  },
  "aggs": {
    "by_ip": {
      "terms": {
        "field": "data.srcip",
        "size": 5,
        "order": {
          "ports": "desc"
        }
      },
      "aggs": {
        "ports": {
          "cardinality": {
            "field": "data.dstport"
          }
        },
        "dsts": {
          "cardinality": {
            "field": "data.dstip"
          }
        },
        "days": {
          "date_histogram": {
            "field": "timestamp",
            "fixed_interval": "1d",
            "time_zone": "+09:00",
            "min_doc_count": 1
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · Date Histogram(시간) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R02 · Terms(버킷) · Cardinality(고유 수) · Date Histogram(시간)

R02 Q6 결과 읽기 — 방화벽 차단 (DROP) — IP 별 서로 다른 포트 · 목적지 수 · 활동 일수

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	고유 포트 수	고유 목적지 수	활동 일수
142.66.143.170	873	98	8	55
136.36.241.64	12	10	8	12
154.48.174.222	11	10	7	11
138.147.107.170	10	9	7	9
30.248.117.242	10	9	5	10

왜 이걸 보나 — FW DROP 은 IP 별 '서로 다른 포트 수'로 본다. 포트 40 개 + 는 스캔.

Visualize 로 같은 표

Split rows: Terms data.srcip size 5 · 정렬 ports desc → Metric: Unique Count data.dstport → Metric: Unique Count data.dstip → Split rows: Date Histogram timestamp 간격 1d

R02 Q7 집계 쿼리 — 두 정찰 IP(142.66.143.170, 221.49.17.120) 의 일별 활동 (일 단위 , 많은 날 순)

```
POST purple-r02/_search
{
  "size": 0,
  "query": {
    "bool": {
      "should": [
        {
          "term": {
            "data.srcip": "142.66.143.170"
          }
        },
        {
          "term": {
            "data.srcip": "221.49.17.120"
          }
        },
        {
          "term": {
            "data.src_ip": "142.66.143.170"
          }
        }
      ]
    }
  },
  "aggs": {
    "t": {
      "date_histogram": {
        "field": "timestamp",
        "fixed_interval": "1d",
        "time_zone": "+09:00",
        "format": "yyyy-MM-dd",
        "min_doc_count": 1,
        "order": {
          "_count": "desc"
        }
      },
      "aggs": {
        "who": {
          "terms": {
            "field": "decoder.name",
            "size": 2
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Date Histogram(시간) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R02 Q7 결과 읽기 — 두 정찰 IP(142.66.143.170, 221.49.17.120) 의 일별 활동 (일 단위 , 많은 날 순) (1/2)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

날짜	값	건수
2026-10-12	kt66-nft	768
2026-10-12	json	12
2026-10-28	web-accesslog	240
2026-09-15	web-accesslog	40
2026-10-03	web-accesslog	25
2026-10-03	kt66-nft	1
2026-10-20	web-accesslog	26

R02 Q7 결과 읽기 — 두 정찰 IP(142.66.143.170, 221.49.17.120) 의 일별 활동 (일 단위 , 많은 날 순) (2/2)

날짜	값	건수
2026-09-05	web-accesslog	16

왜 이걸 보나 — 두 정찰 IP 의 일별 활동 — 하루짜리 폭주와 장기 저속이 섞여 있다 .

Visualize 로 같은 표

```
Split rows: Date Histogram timestamp 간격 1d →
Split rows: Terms decoder.name size 2
```

R02 · Terms(버킷) · Cardinality(고유 수) · Date Histogram(시간) · Max(최대) · Min(최소)

R02 Q8 집계 쿼리 — 404 고유 URL 상위 IP 의 활동 일수 · 처음 · 마지막 (장기 정찰 판별)

```
POST purple-r02/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        },
        {
          "term": {
            "data.id": "404"
          }
        }
      ]
    }
  },
  "aggs": {
    "by_ip": {
      "terms": {
        "field": "data.srcip",
        "size": 5,
        "order": {
          "urls": "desc"
        }
      },
      "aggs": {
        "urls": {
          "cardinality": {
            "field": "data.url"
          }
        },
        "days": {
          "date_histogram": {
            "field": "timestamp",
            "fixed_interval": "1d",
            "time_zone": "+09:00",
            "min_doc_count": 1
          }
        },
        "first": {
          "min": {
            "field": "timestamp"
          }
        },
        "last": {
          "max": {
            "field": "timestamp"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · Date Histogram(시간) · Max(최대) · Min(최소) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R02 · Terms(버킷) · Cardinality(고유 수) · Date Histogram(시간) · Max(최대) · Min(최소)

R02 Q8 결과 읽기 — 404 고유 URL 상위 IP 의 활동 일수 · 처음 · 마지막 (장기 정찰 판별)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	고유 URL 수	활동 일수	처음	마지막
221.49.17.120	241	5	2026-09-05	2026-10-28
196.112.185.106	102	63	2026-08-03	2026-10-31
15.80.134.2	69	51	2026-08-03	2026-10-31
150.173.171.62	62	48	2026-08-03	2026-10-31
135.89.117.84	61	47	2026-08-03	2026-10-31

왜 이걸 보나 — 처음 · 마지막 · 활동 일수로 장기 정찰을 판별한다 (실제 로그의 재방문 패턴).

Visualize 로 같은 표

Split rows: Terms data.srcip size 5 · 정렬 urls desc → Metric: Unique Count data.url → Split rows: Date Histogram timestamp 간격 1d → Metric: Min timestamp → Metric: Max timestamp

R02 모니터 — 집계를 경보로

경보는 '한 줄'이 아니라 '조건을 넘는 집계 결과'로 울린다 — bucket_selector 로 거른 뒤 OpenSearch Alerting 모니터로 자동화한다.

모니터

404 를 받은 서로 다른 URL 이 100 개 이상인 IP — 트리거 `ctx.results[0].aggregations.by_ip.buckets.size() > 0`

지금 걸리는 대상

값	건수	고유 URL 수
221.49.17.120	341	241
196.112.185.106	119	102

트리거

```
ctx.results[0].aggregations.by_ip.buckets.size() > 0
```

R02 규칙 팩 — 같은 판단을 자동화 (1/3)

집계로 '찾은' 판단을 서명 (Suricata·ModSecurity)· 상관 (Wazuh)·Sigma·osquery 규칙으로 바꿔 자동 탐지한다 .

도구	ID	내용
Suricata	9602001	PURPLE R02 inbound SYN sweep - 40 SYN/60s from one source
Suricata	9602002	PURPLE R02 404 storm - 30 not-found responses/120s to one client
Suricata	9602003	PURPLE R02 hidden neobank API path probe
ModSecurity	90201	PURPLE R02 hidden API probe

R02 규칙 팩 — 같은 판단을 자동화 (2/3)

도구	ID	내용
ModSecurity	90203	PURPLE R02 404 storm - client throttled (%{ip.r02_404})
Wazuh	190201 (L10)	PURPLE R02: 같은 IP 가 2 분에 4xx 30 회 이상 — 웹 경로 대입 의심 $(srcip) [빈도 30/120s]
Wazuh	190202 (L6)	PURPLE R02: 숨은 API 경로 탐침 $(srcip) $(url)
Wazuh	190203 (L12)	PURPLE R02: 하루에 서로 다른 IP 20 곳이 같은 숨은 API 를 탐침 — 분산 저속 정찰 [빈도 20/86400s]
Wazuh	190204 (L3)	PURPLE R02: FW 차단 $(srcip) → $(dstip):$(dstport)

R02 규칙 팩 — 같은 판단을 자동화 (3/3)

도구	ID	내용
Wazuh	190205 (L10)	PURPLE R02: 1 분에 서로 다른 포트 40 개 이상 차단 — 포트 스캔 $(srcip) [빈도 40/60s]
Sigma	단건	PURPLE R02 Hidden API Path Probe
Sigma	상관	PURPLE R02 Distributed Probe - 20 sources per day

R02 대응 — 그래서 무엇을 하나

대응

스캔 IP(190205) 는 firewall-drop 10 분 , 분산 정찰 (190203) 은 IP 차단이 소용없다 → 숨은 API 를 외부에서 404 로 숨기고 (ModSec 90201) 경로 자체를 닫는다 .

생각해 볼 것

- 서명 (한 줄)· 상관 (분 ~ 일)· 집계 (전체 기간) 중 이 라운드의 공격을 처음 드러낸 것은 무엇인가 ?
- 정상 99.9% 안에서 임계값을 어디에 두면 오탐이 0 이 되는가 ? (미션 2~4 의 분포로 근거를 댄다)
- 공격자가 기간을 두 배로 늘리면 (--days 180) 어떤 집계가 약해지고 어떤 집계가 강해지는가 ?

R02 한 장 정리

결정적 집계	IP 별 고유 URL 수 · 고유 포트 수 , 경로별 고유 IP 수
찾은 것	404 고유 URL 241 개 · DROP 포트 98 개 · 숨은 API 한 경로에 IP 226 곳
규칙	Suricata SYN·404 threshold · ModSec IP 카운터 · Wazuh different_srcip

분산 · 장기 공격은 서명 · 상관에서 0 건이 정상 — 그래서 집계가 먼저다 .

R03 · 웹 취약점 공격

초기 침투 (웹) — 차단 뒤 통과로 바뀐 IP

차단 (403) 이 반복되던 IP 가 어느 순간 통과 (200) 로 바뀐다 — 같은 IP 의 응답 코드 구성비로 WAF 우회를 찾는다

총 2,442,618 건 · 공격 1,490 건 · 정상 (배경 포함) 99.939%

R03 시나리오 — 무엇이 일어났나

R03 초기 침투 (웹) — WAF 에 막히다가 어느 순간 ' 통과하기 시작한 ' IP 를 집계로 잡는다 .

Red — 공격 (로그로만 재현 , 실제 공격 없음)

- 1) 경로 탐색 (소량) → 2) /api/history?page= 에 SQLi 대입 — WAF 차단 (403)
- 3) 인코딩 · 주석 · 대소문자 섞기로 우회 — 200·500 응답 4) UNION 덤프 — 응답 크기 수 MB

Blue — 집계로 찾기

- WAF 차단 상위 (교육용 DVWA 소음 구분) → 같은 IP 의 차단 · 통과 동시 존재 → 응답 크기 이상 → 우회 패턴 → 500 → 타임라인

R03 데이터 — 정상의 모양부터 (1/2)

총 2,442,618 건 · 공격 1,490 건 · 정상 (배경 포함) 99.939%

기간 기본 90 일 (D-90 ~ D-1). 기준일 2026-11-01 이면 정답 키와 숫자가 같다

인덱스 `purple-r03` · 인덱스 패턴 `purple-*` · 시간 필드 `timestamp`

엔드포인트 — 시스템마다 가상 IP

시스템	IP
juice.kt66.lab	198.51.100.81
dvwa.kt66.lab	198.51.100.82
neobank.kt66.lab	198.51.100.83

R03 데이터 — 정상의 모양부터 (2/2)

시스템	IP
govportal.kt66.lab	198.51.100.84
mediforum.kt66.lab	198.51.100.85
admin.kt66.lab	198.51.100.86
ai.kt66.lab	198.51.100.87
webmail.kt66.lab	198.51.100.26
bastion	10.20.30.201
KT66-WIN-01	10.20.70.10

R03 Q1 집계 쿼리 — WAF 차단 상위 IP 와 대상 vhost

```
POST purple-r03/_search
{
  "size": 0,
  "query": {
    "term": {
      "rule.id": "100210"
    }
  },
  "aggs": {
    "by_ip": {
      "terms": {
        "field": "data.srcip",
        "size": 6
      },
      "aggs": {
        "vh": {
          "terms": {
            "field": "data.vhost",
            "size": 1
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R03 Q1 결과 읽기 — WAF 차단 상위 IP 와 대상 vhost

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
218.136.73.91	neobank.kt66.lab	516
104.237.84.10	govportal.kt66.lab	2
112.96.94.223	juice.kt66.lab	2
146.243.235.63	neobank.kt66.lab	2
154.139.184.22	govportal.kt66.lab	1
42.241.46.215	ai.kt66.lab	1

왜 이걸 보나 — WAF 가 막은 것부터 — 차단이 많은 IP 는 '시도한' IP 다.

Visualize 로 같은 표

Split rows: Terms data.srcip size 6 → Split rows: Terms data.vhost size 1

R03 Q2 집계 쿼리 — neobank — 같은 IP 의 차단 (403)· 통과 (200)· 오류 (500) 동시 집계 (차단 순)

```
POST purple-r03/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        },
        {
          "term": {
            "data.vhost": "neobank.kt66.lab"
          }
        }
      ]
    }
  },
  "aggs": {
    "by_ip": {
      "terms": {
        "field": "data.srcip",
        "size": 5,
        "order": {
          "blocked": "desc"
        }
      },
      "aggs": {
        "blocked": {
          "filter": {
            "term": {
              "data.id": "403"
            }
          }
        },
        "ok": {
          "filter": {
            "term": {
              "data.id": "200"
            }
          }
        },
        "err": {
          "filter": {
            "term": {
              "data.id": "500"
            }
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R03 Q2 결과 읽기 — neobank — 같은 IP 의 차단 (403)· 통과 (200)· 오류 (500) 동시 집계 (차단 순)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	blocked	ok	err
218.136.73.91	974	516	362	24
146.243.235.63	3	2	0	0
147.129.230.180	6	2	0	0
148.11.88.211	3	2	0	0
174.90.64.181	4	2	0	0

왜 이걸 보나 — filters 집계로 403·200·500 을 같은 IP 버킷에 나란히 — 403 만 있는 IP 와 403+200 이 같이 있는 IP 는 전혀 다르다 .

Visualize 로 같은 표

Split rows: Terms data.srcip size 5 · 정렬 blocked>_count desc → (하위 필터 : data.id:"403") → (하위 필터 : data.id:"200") → (하위 필터 : data.id:"500")

R03 Q3 집계 쿼리 — neobank /api/history — IP 별 최대 · 평균 응답 크기 (최대 순)

```
POST purple-r03/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        },
        {
          "term": {
            "data.vhost": "neobank.kt66.lab"
          }
        },
        {
          "prefix": {
            "data.url": "/api/history"
          }
        }
      ]
    }
  },
  "aggs": {
    "by_ip": {
      "terms": {
        "field": "data.srcip",
        "size": 5,
        "order": {
          "mx": "desc"
        }
      },
      "aggs": {
        "mx": {
          "max": {
            "field": "data.bytes"
          }
        },
        "av": {
          "avg": {
            "field": "data.bytes"
          }
        },
        "tot": {
          "sum": {
            "field": "data.bytes"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Sum(합계) · Max(최대) · Avg(평균) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R03 · Terms(버킷) · Sum(합계) · Max(최대) · Avg(평균)

R03 Q3 결과 읽기 — neobank /api/history — IP 별 최대 · 평균 응답 크기 (최대순)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	mx	av	tot
218.136.73.91	886	5189279	85516	72
121.59.151.169	2	26516	16719	0
171.166.77.52	4	24942	10850	0
3.175.124.2	1	24624	24624	0
48.214.55.138	1	24621	24621	0

왜 이걸 보나 — 응답 크기의 최대값이 평균의 수백 배면 그 요청이 덤프다 .

Visualize 로 같은 표

```
Split rows: Terms data.srcip size 5 · 정렬 mx desc →
Metric: Max data.bytes → Metric: Average data.bytes →
Metric: Sum data.bytes
```

R03 Q4 집계 쿼리 — WAF 를 통과한 요청의 우회 흔적 — 패턴별 건수

```
POST purple-r03/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        },
        {
          "term": {
            "data.vhost": "neobank.kt66.lab"
          }
        }
      ],
      "must_not": [
        {
          "term": {
            "data.id": "403"
          }
        }
      ]
    }
  },
  "aggs": {
    "pat": {
      "filters": {
        "filters": {
          "2_double_enc": {
            "wildcard": {
              "data.url": "*%25*"
            }
          },
          "3_mixed_case": {
            "wildcard": {
              "data.url": "*uNiOn*"
            }
          },
          "4_char_fn": {
            "wildcard": {
              "data.url": "*ChAr(*"
            }
          },
          "5_newline": {
            "wildcard": {
              "data.url": "*%0a*"
            }
          }
        }
      }
    }
  }
}
```

집계 기법 : Filters(조건별) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R03 Q4 결과 읽기 — WAF 를 통과한 요청의 우회 흔적 — 패턴별 건수

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수
2_double_enc	60
3_mixed_case	77
4_char_fn	55
5_newline	66

왜 이걸 보나 — 통과한 요청 안에 우회 흔적 (주석 · 이중 인코딩) 이 있으면 CRS 가 놓친 것이다 .

Visualize 로 같은 표

Split rows: Filters (2_double_enc / 3_mixed_case / 4_char_fn / 5_newline)

R03 Q5 집계 쿼리 — neobank 500 응답 상위 IP

```
POST purple-r03/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        },
        {
          "term": {
            "data.vhost": "neobank.kt66.lab"
          }
        },
        {
          "term": {
            "data.id": "500"
          }
        }
      ]
    }
  },
  "aggs": {
    "by_ip": {
      "terms": {
        "field": "data.srcip",
        "size": 5
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter).
size:0 = 원문 로그는 안 가져오고 집계 숫자만

R03 Q5 결과 읽기 — neobank 500 응답 상위 IP

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수
218.136.73.91	24
210.144.16.116	13
141.231.138.251	5
87.227.41.4	5
167.126.15.72	2

왜 이걸 보나 — 500 은 쿼리가 깨졌다는 뜻 — SQLi 도구가 문법을 맞추는 과정의 흔적 .

Visualize 로 같은 표

```
Split rows: Terms data.srcip size 5
```

R03 Q6 집계 쿼리 — 공격 IP 218.136.73.91 의 10 분 단위 응답 코드 흐름 (본 공격일)

```
POST purple-r03/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        },
        {
          "term": {
            "data.srcip": "218.136.73.91"
          }
        }
      ]
    }
  },
  "aggs": {
    "t": {
      "date_histogram": {
        "field": "timestamp",
        "fixed_interval": "10m",
        "time_zone": "+09:00",
        "format": "MM-dd HH:mm",
        "min_doc_count": 1
      },
      "aggs": {
        "st": {
          "terms": {
            "field": "data.id",
            "size": 4
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Date Histogram(시간) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R03 · Terms(버킷) · Date Histogram(시간)

R03 Q6 결과 읽기 — 공격 IP 218.136.73.91 의 10 분 단위 응답 코드 흐름 (본 공격일) (1/2)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

날짜	값	건수
08-24 07:00	403	1
08-24 07:10	403	1
08-24 07:30	403	1
08-24 07:40	403	1
08-24 07:50	403	1
08-24 08:00	200	1
08-24 08:00	403	1

R03 Q6 결과 읽기 — 공격 IP 218.136.73.91 의 10 분 단위 응답 코드 흐름 (본 공격일) (2/2)

날짜	값	건수
08-24 08:20	403	1

왜 이걸 보나 — 10 분 버킷으로 403 → 200 전환 시점을 본다 . 전환 시각이 ' 우회 성공 ' 시각이다 .

Visualize 로 같은 표

Split rows: Date Histogram timestamp 간격 10m
→ Split rows: Terms data.id size 4

R03 Q7 집계 쿼리 — 공격 IP 218.136.73.91 — 활동 일수와 처음 · 마지막 접근 (장기 탐침)

```
POST purple-r03/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        },
        {
          "term": {
            "data.srcip": "218.136.73.91"
          }
        }
      ]
    }
  },
  "aggs": {
    "ip": {
      "terms": {
        "field": "data.srcip",
        "size": 1
      },
      "aggs": {
        "days": {
          "date_histogram": {
            "field": "timestamp",
            "fixed_interval": "1d",
            "time_zone": "+09:00",
            "min_doc_count": 1
          }
        },
        "first": {
          "min": {
            "field": "timestamp"
          }
        },
        "last": {
          "max": {
            "field": "timestamp"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Date Histogram(시간) · Max(최대) · Min(최소) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R03 Q7 결과 읽기 — 공격 IP 218.136.73.91 — 활동 일수와 처음 · 마지막 접근 (장기 탐침)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	활동 일수	처음	마지막
218.136.73.91	974	4	2026-08-24	2026-10-28

왜 이걸 보나 — 본 공격 전 몇 주의 탐침 — 처음 · 마지막 · 활동 일수 .

Visualize 로 같은 표

```
Split rows: Terms data.srcip size 1 → Split rows: Date Histogram timestamp 간격 1d → Metric: Min timestamp → Metric: Max timestamp
```

R03 모니터 — 집계를 경보로

경보는 '한 줄'이 아니라 '조건을 넘는 집계 결과'로 울린다 — bucket_selector 로 거른 뒤 OpenSearch Alerting 모니터로 자동화한다.

모니터

같은 IP 가 같은 사이트에서 403 20 회 이상 + 200 20 회 이상 (차단 뒤 통과) — 트리거 `ctx.results[0].aggregations.by_ip.buckets.size() > 0`

지금 걸리는 대상

값	blocked	ok
218.136.73.91	516	362

트리거

```
ctx.results[0].aggregations.by_ip.buckets.size() > 0
```

R03 규칙 팩 — 같은 판단을 자동화

집계로 '찾은' 판단을 서명 (Suricata·ModSecurity)· 상관 (Wazuh)·Sigma·osquery 규칙으로 바꿔 자동 탐지한다 .

도구	ID	내용
Suricata	9603001	PURPLE R03 SQLi obfuscation - inline comment + UNION (mixed case)
Suricata	9603002	PURPLE R03 SQLi obfuscation - double URL encoding of quote
Suricata	9603003	PURPLE R03 SQLi tool cadence - 50 /api/history param requests in 5 min
ModSecurity	90301	PURPLE R03 double URL encoding
ModSecurity	90302	PURPLE R03 SQL inline-comment obfuscation
ModSecurity	90304	PURPLE R03 repeat offender (%{ip.r03_blocks} blocks)
Wazuh	190301 (L8)	PURPLE R03: 10 분에 /api/history 4xx 20 회 이상 $(srcip) — SQLi 대입 중 [빈도 20/600s]
Wazuh	190302 (L13)	PURPLE R03: 차단이 반복되던 $(srcip) 의 SQLi 요청이 200 으로 통과 — WAF 우회 성공 [순서 7200s]
Sigma	단건	PURPLE R03 SQLi Request Blocked
Sigma	단건	PURPLE R03 Obfuscated SQLi Passed
Sigma	상관	PURPLE R03 Blocked then Bypassed (same source)

R03 대응 — 그래서 무엇을 하나

대응

190302(차단→통과) 발생 시 그 IP 를 즉시 차단 (firewall-drop 30 분) 하고 , 통과한 우회 패턴을 ModSec 90301·90302 로 막는다 . 덤프된 기간의 /api/history 응답은 유출 범위 산정에 쓴다 .

생각해 볼 것

- 서명 (한 줄)· 상관 (분 ~ 일)· 집계 (전체 기간) 중 이 라운드의 공격을 처음 드러낸 것은 무엇인가 ?
- 정상 99.9% 안에서 임계값을 어디에 두면 오탐이 0 이 되는가 ? (미션 2~4 의 분포로 근거를 댄다)
- 공격자가 기간을 두 배로 늘리면 (--days 180) 어떤 집계가 약해지고 어떤 집계가 강해지는가 ?

R03 한 장 정리

결정적 집계	같은 IP 의 403·200·500 을 filters 로 한 줄에
찾은 것	차단 516 · 통과 362 · 최대 응답 5.2MB (평균의 60 배)
규칙	이중 인코딩 · 주석 SQLi 보강 · 반복 차단자 고정 창 · Wazuh 차단→통과 순서

분산 · 장기 공격은 서명 · 상관에서 0 건이 정상 — 그래서 집계가 먼저다 .

R04 · 지속화 · 웹셸

실행 · 지속성 — 수천 건 속 한 건

수천 건의 정상 업로드 · 명령 속에서 업로드 폴더의 .php 한 건 , apache2→sh 한 쌍을 찾는다

총 2,457,124 건 · 공격 997 건 · 정상 (배경 포함) 99.959%

R04 시나리오 — 무엇이 일어났나

R04 실행 · 지속성 — 업로드 이미지 수천 장 속 PHP 한 개 , cron 실행 수만 건 속 /tmp 스크립트 하나 .

Red — 공격 (로그로만 재현 , 실제 공격 없음)

- 1) 이미지로 위장한 웹셸 업로드 (FIM 554) → 2) 웹셸로 명령 실행 (웹 GET + auditd: apache2 → sh)
- 3) 지속성 : 계정 생성 (5902)·/etc/passwd·shadow 변경 ·cron.d 추가 ·root authorized_keys·rc.local
- 4) cron 이 10 분마다 /tmp/.x/update.sh 실행 (auditd)

Blue — 집계로 찾기

- 업로드 FIM 확장자 분포 → 부모 - 자식 프로세스 쌍 → 업로드 경로 PHP 호출 IP → /etc·/root 변경 → 주기 실행 → 타임라인

R04 데이터 — 정상의 모양부터 (1/2)

총 2,457,124 건 · 공격 997 건 · 정상 (배경 포함) 99.959%

기간	기본 90 일 (D-90 ~ D-1). 기준일 2026-11-01 이면 정답 키와 숫자가 같다
인덱스	`purple-r04` · 인덱스 패턴 `purple-*` · 시간 필드 `timestamp`

엔드포인트 — 시스템마다 가상 IP

시스템	IP
juice.kt66.lab	`198.51.100.81`
dvwa.kt66.lab	`198.51.100.82`
neobank.kt66.lab	`198.51.100.83`

R04 데이터 — 정상의 모양부터 (2/2)

시스템	IP
govportal.kt66.lab	198.51.100.84
mediforum.kt66.lab	198.51.100.85
admin.kt66.lab	198.51.100.86
ai.kt66.lab	198.51.100.87
webmail.kt66.lab	198.51.100.26
bastion	10.20.30.201
KT66-WIN-01	10.20.70.10

R04 Q1 집계 쿼리 — 파일 추가 (FIM 554) — 업로드 폴더 확장자별

```
POST purple-r04/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "rule.id": "554"
          }
        },
        {
          "wildcard": {
            "syscheck.path": "/var/www
              /*/uploads/*"
          }
        }
      ]
    }
  },
  "aggs": {
    "ext": {
      "filters": {
        "filters": {
          "1_jpg": {
            "wildcard": {
              "syscheck.path": "*.jpg"
            }
          },
          "2_png": {
            "wildcard": {
              "syscheck.path": "*.png"
            }
          },
          "3_pdf": {
            "wildcard": {
              "syscheck.path": "*.pdf"
            }
          },
          "4_php": {
            "wildcard": {
              "syscheck.path": "*.php"
            }
          }
        }
      }
    }
  }
}
```

집계 기법 : Filters(조건별) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R04 Q1 결과 읽기 — 파일 추가 (FIM 554) — 업로드 폴더 확장자별

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수
1_jpg	871
2_png	432
3_pdf	408
4_php	1

왜 이걸 보나 — 업로드 폴더에는 이미지가 쌓인다 — 확장자 분포에서 .php 한 줄이 튄다 .

Visualize 로 같은 표

Split rows: Filters (1_jpg / 2_png / 3_pdf / 4_php)

R04 Q2 집계 쿼리 — auditd — 부모 프로세스 × 실행 파일 쌍

```
POST purple-r04/_search
{
  "size": 0,
  "query": {
    "term": {
      "decoder.name": "auditd"
    }
  },
  "aggs": {
    "parent": {
      "terms": {
        "field": "data.audit.parent",
        "size": 5
      },
      "aggs": {
        "exe": {
          "terms": {
            "field": "data.audit.exe",
            "size": 4
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R04 Q2 결과 읽기 — auditd — 부모 프로세스 × 실행 파일 쌍

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
/usr/sbin/cron	/usr/bin/php	12142
/usr/sbin/cron	/tmp/.x/update.sh	937
/usr/bin/bash	/usr/bin/systemctl	1114
/usr/bin/bash	/usr/bin/top	1108
/usr/bin/bash	/usr/bin/tail	1072
/usr/bin/bash	/usr/bin/journalctl	1066
/usr/sbin/apache2	/bin/sh	25

왜 이걸 보나 — 부모 × 자식 쌍은 대부분 몇 가지로 고정된다 . apache2→sh 는 정상에 없다 .

Visualize 로 같은 표

Split rows: Terms data.audit.parent size 5 → Split rows: Terms data.audit.exe size 4

R04 Q3 집계 쿼리 — 업로드 폴더의 .php 를 호출한 IP

```
POST purple-r04/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        },
        {
          "wildcard": {
            "data.url": "/uploads/*.php*"
          }
        }
      ]
    }
  },
  "aggs": {
    "by_ip": {
      "terms": {
        "field": "data.srcip",
        "size": 5
      },
      "aggs": {
        "urls": {
          "cardinality": {
            "field": "data.url"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R04 Q3 결과 읽기 — 업로드 폴더의 .php 를 호출한 IP

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	고유 URL 수
70.246.138.5	25	21

왜 이걸 보나 — 그 .php 를 부른 IP 는 하나 — 업로드한 IP 와 같은가?

Visualize 로 같은 표

```
Split rows: Terms data.srcip size 5 → Metric: Unique Count data.url
```

R04 Q4 집계 쿼리 — /etc · /root 아래 파일 변경 (FIM) 과 계정 생성

```
POST purple-r04/_search
{
  "size": 0,
  "query": {
    "bool": {
      "should": [
        {
          "prefix": {
            "syscheck.path": "/etc/"
          }
        },
        {
          "prefix": {
            "syscheck.path": "/root/"
          }
        },
        {
          "term": {
            "rule.id": "5902"
          }
        }
      ]
    }
  },
  "aggs": {
    "by_agent": {
      "terms": {
        "field": "agent.name",
        "size": 3
      },
      "aggs": {
        "what": {
          "terms": {
            "field": "rule.description",
            "size": 4
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter).
size:0 = 원문 로그는 안 가져오고 집계 숫자만

R04 Q4 결과 읽기 — /etc · /root 아래 파일 변경 (FIM) 과 계정 생성

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
mediforum	Integrity checksum changed.	5
mediforum	File added to the system.	1
mediforum	New user added to the system.	1

왜 이걸 보나 — /etc·/root 변경과 계정 생성이 웹셸 호출 뒤에 붙어 있으면 지속성 확보다 .

Visualize 로 같은 표

Split rows: Terms agent.name size 3 → Split rows: Terms rule.description size 4

R04 Q5 집계 쿼리 — cron 이 실행한 파일 — 건수와 처음 · 마지막 시각

```
POST purple-r04/_search
{
  "size": 0,
  "query": {
    "term": {
      "data.audit.parent": "/usr/sbin/cron"
    }
  },
  "aggs": {
    "exe": {
      "terms": {
        "field": "data.audit.exe",
        "size": 3
      },
      "aggs": {
        "first": {
          "min": {
            "field": "timestamp"
          }
        },
        "last": {
          "max": {
            "field": "timestamp"
          }
        },
        "hosts": {
          "cardinality": {
            "field": "agent.name"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · Max(최대) · Min(최소) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R04 Q5 결과 읽기 — cron 이 실행한 파일 — 건수와 처음 · 마지막 시각

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	고유 vhost 수	first	last
/usr/bin/php	12142	6	08-03 00:05	10-31 23:48
/tmp/.x/update.sh	937	1	09-22 23:00	10-31 23:00

왜 이걸 보나 — cron 이 실행한 파일의 처음 · 마지막 — 몇 주 동안 살아 있었나 .

Visualize 로 같은 표

```
Split rows: Terms data.audit.exe size 3 → Metric: Min timestamp → Metric: Max timestamp → Metric: Unique Count agent.name
```

R04 Q6 집계 쿼리 — mediforum 침투 첫날 타임라인 — 10 분 단위 (웹셸 호출 ·auditd·FIM· 계정)

```
POST purple-r04/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "agent.name": "mediforum"
          }
        }
      ],
      "should": [
        {
          "term": {
            "data.srcip": "70.246.138.5"
          }
        },
        {
          "term": {
            "data.audit.parent": "/usr/sbin
              /apache2"
          }
        },
        {
          "prefix": {
            "syscheck.path": "/etc/"
          }
        },
        {
          "prefix": {
            "syscheck.path": "/root/"
          }
        },
        {
          "wildcard": {
            "syscheck.path": "*.php"
          }
        },
        {
          "term": {
            "rule.id": "5902"
          }
        }
      ],
      "minimum_should_match": 1
    }
  },
  "aggs": {
    "t": {
      "date_histogram": {
        "field": "timestamp",
        "fixed_interval": "10m",
        "time_zone": "+09:00",
        "format": "MM-dd HH:mm",
        "min_doc_count": 1
      },
      "aggs": {
        "what": {
          "terms": {
            "field": "decoder.name",
            "size": 4
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Date Histogram(시간) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R04 Q6 결과 읽기 — mediforum 침투 첫날 타임라인 — 10 분 단위 (웹셸 호출 ·auditd·FIM· 계정) (1/2)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

날짜	값	건수
09-22 22:00	syscheck_new_entry	1
09-22 22:00	web-accesslog	1
09-22 22:10	auditd	4
09-22 22:10	web-accesslog	4
09-22 22:20	auditd	7
09-22 22:20	web-accesslog	7
09-22 22:30	auditd	5

R04 Q6 결과 읽기 — mediforum 침투 첫날 타임라인 — 10 분 단위 (웹셸 호출 ·auditd·FIM· 계정) (2/2)

날짜	값	건수
09-22 22:30	web-accesslog	5

왜 이걸 보나 — 10 분 버킷 타임라인 — 웹셸 ·auditd·FIM· 계정 이벤트가 같은 칸에 모인다 .

Visualize 로 같은 표

```
Split rows: Date Histogram timestamp 간격 10m
→ Split rows: Terms decoder.name size 4
```

R04 Q7 집계 쿼리 — 웹셸 호출 IP 의 주별 접근 횟수 (장기 잠복)

```
POST purple-r04/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        },
        {
          "wildcard": {
            "data.url": "/uploads/*.php*"
          }
        }
      ]
    }
  },
  "aggs": {
    "w": {
      "date_histogram": {
        "field": "timestamp",
        "fixed_interval": "7d",
        "time_zone": "+09:00",
        "format": "yyyy-MM-dd",
        "min_doc_count": 1
      }
    }
  }
}
```

집계 기법 : Date Histogram(시간) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R04 Q7 결과 읽기 — 웹셸 호출 IP 의 주별 접근 횟수 (장기 잠복)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

key_as_string	건수
2026-09-17	18
2026-09-24	2
2026-10-01	3
2026-10-08	1
2026-10-22	1

왜 이걸 보나 — 웹셸 호출 IP 의 주별 접근 — 한 번 쓰고 버리지 않고 몇 주에 걸쳐 돌아온다 .

Visualize 로 같은 표

```
Split rows: Date Histogram timestamp 간격 7d
```

R04 모니터 — 집계를 경보로

경보는 '한 줄'이 아니라 '조건을 넘는 집계 결과'로 울린다 — bucket_selector 로 거른 뒤 OpenSearch Alerting 모니터로 자동화한다.

모니터

웹서버 프로세스 (apache2) 가 셸을 실행한 호스트 — 트리거 `ctx.results[0].aggregations.by_agent.buckets.size() > 0`

지금 걸리는 대상

값	건수
mediforum	25

트리거

```
ctx.results[0].aggregations.by_agent.buckets.size() > 0
```

R04 규칙 팩 — 같은 판단을 자동화 (1/3)

집계로 '찾은' 판단을 서명 (Suricata·ModSecurity)· 상관 (Wazuh)·Sigma·osquery 규칙으로 바꿔 자동 탐지한다 .

도구	ID	내용
Suricata	9604001	PURPLE R04 PHP executed from uploads directory
Suricata	9604002	PURPLE R04 webshell command parameter (c=)
ModSecurity	90401	PURPLE R04 script request under /uploads
ModSecurity	90402	PURPLE R04 PHP upload attempt
ModSecurity	90403	PURPLE R04 PHP code inside uploaded file

R04 규칙 팩 — 같은 판단을 자동화 (2/3)

도구	ID	내용
Wazuh	190401 (L12)	PURPLE R04: 업로드 폴더 PHP 호출 $(srcip) $(url) — 웹셸 의심
Wazuh	190402 (L14)	PURPLE R04: 웹셸 호출 뒤 2 시간 안에 계정 생성 $(dstuser) — 지속성 확보 [순서 7200s]
Wazuh	190403 (L12)	PURPLE R04: 업로드 폴더에 스크립트 파일 생성 $(file)
Wazuh	190404 (L12)	PURPLE R04: 지속성 관련 파일 변경 $(file)
Sigma	단건	PURPLE R04 Webshell Access under Uploads

R04 규칙 팩 — 같은 판단을 자동화 (3/3)

도구	ID	내용
Sigma	상관	PURPLE R04 Webshell Used Repeatedly (3 in 1h)
osquery	purple_r04_php_in_uploads	R04: 업로드 폴더의 스크립트 파일
osquery	purple_r04_cron_tmp	R04: /tmp·/dev/shm 을 실행하는 cron
osquery	purple_r04_new_users	R04: 로그인 가능한 일반 계정 목록 (기준선과 비교)
osquery	purple_r04_root_keys	R04: root authorized_keys
Sysmon	ProcessCreate	rules/r04/sysmon.xml

R04 대응 — 그래서 무엇을 하나

대응

190401·190403 발생 시 웹셸 파일 격리 (이동 · 해시 기록), 생성 계정 잠금 , cron·authorized_keys 원복 . purple-ar 은 기록만 , 조치는 사람이 확인 후 .

생각해 볼 것

- 서명 (한 줄)· 상관 (분 ~ 일)· 집계 (전체 기간) 중 이 라운드의 공격을 처음 드러낸 것은 무엇인가 ?
- 정상 99.9% 안에서 임계값을 어디에 두면 오탐이 0 이 되는가 ? (미션 2~4 의 분포로 근거를 댄다)
- 공격자가 기간을 두 배로 늘리면 (--days 180) 어떤 집계가 약해지고 어떤 집계가 강해지는가 ?

R04 한 장 정리

결정적 집계	업로드 폴더 확장자 분포 · 부모 × 실행 파일 쌍
찾은 것	jpg 871·png 432 사이 .php 1 건 , apache2→sh 25 회 , IP 1 곳
규칙	ModSec 업로드 · 실행 차단 · Wazuh 웹셸→계정 생성 · osquery·Sysmon

분산 · 장기 공격은 서명 · 상관에서 0 건이 정상 — 그래서 집계가 먼저다 .

R05 · 권한상승 · 방어 회피

권한상승 · 방어회피 — 끊긴 로그도 신호다

www-data 의 sudo, /dev/shm 실행, 그리고 '로그가 0 건인 시간' — 사라진 로그도 집계하면 신호다

총 2,457,928 건 · 공격 119 건 · 정상 (배경 포함) 99.995%

R05 시나리오 — 무엇이 일어났나

R05 권한상승 · 방어회피 — sudo 를 쓰지 않던 계정 , /dev/shm 의 [kworker], 그리고 ' 로그가 끊긴 2 시간 '.

Red — 공격 (로그로만 재현 , 실제 공격 없음)

- 1) sudo -l 실패 반복 → find -exec 로 root 셸 2) /dev/shm 에 커널 스레드 이름으로 위장한 프로세스
- 3) auth.log 비우기 ·history 삭제 ·wazuh-agent 중지 → 약 2 시간 로그 공백 4) 재시작 후 FIM 이 삭제를 보고

Blue — 집계로 찾기

- sudo 사용자 분포 → www-data 명령 → 10 분 단위 0 건 구간 → 수상 경로 실행 → 삭제 파일 → 타임라인

R05 데이터 — 정상의 모양부터 (1/2)

총 2,457,928 건 · 공격 119 건 · 정상 (배경 포함) 99.995%

기간	기본 90 일 (D-90 ~ D-1). 기준일 2026-11-01 이면 정답 키와 숫자가 같다
인덱스	`purple-r05` · 인덱스 패턴 `purple-*` · 시간 필드 `timestamp`

엔드포인트 — 시스템마다 가상 IP

시스템	IP
juice.kt66.lab	`198.51.100.81`
dvwa.kt66.lab	`198.51.100.82`
neobank.kt66.lab	`198.51.100.83`

R05 데이터 — 정상의 모양부터 (2/2)

시스템	IP
govportal.kt66.lab	198.51.100.84
mediforum.kt66.lab	198.51.100.85
admin.kt66.lab	198.51.100.86
ai.kt66.lab	198.51.100.87
webmail.kt66.lab	198.51.100.26
bastion	10.20.30.201
KT66-WIN-01	10.20.70.10

R05 Q1 집계 쿼리 — sudo 사용자 × 결과 (rule.id)

```
POST purple-r05/_search
{
  "size": 0,
  "query": {
    "term": {
      "decoder.name": "sudo"
    }
  },
  "aggs": {
    "u": {
      "terms": {
        "field": "data.srcuser",
        "size": 20,
        "order": {
          "_key": "asc"
        }
      },
      "aggs": {
        "r": {
          "terms": {
            "field": "rule.id",
            "size": 2
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter).
size:0 = 원문 로그는 안 가져오고 집계 숫자만

R05 Q1 결과 읽기 — sudo 사용자 × 결과 (rule.id) (1/2)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
kim.chaewon	5402	187
kim.doyun	5402	186
kim.eunwoo	5402	193
kim.hajun	5402	154
kim.hayun	5402	178
kim.jiho	5402	165
kim.jimin	5402	191

R05 Q1 결과 읽기 — sudo 사용자 × 결과 (rule.id) (2/2)

구분	값	건수
kim.jiwoo	5402	172

왜 이걸 보나 — sudo 를 쓰는 사람은 정해져 있다 (관리자 15 명). 목록 밖의 이름이 신호다 .

Visualize 로 같은 표

Split rows: Terms data.srcuser size 20 · 정렬 _key asc → Split rows: Terms rule.id size 2

R05 Q2 집계 쿼리 — www-data 가 sudo 로 실행하려 한 명령

```
POST purple-r05/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "sudo"
          }
        },
        {
          "term": {
            "data.srcuser": "www-data"
          }
        }
      ]
    }
  },
  "aggs": {
    "c": {
      "terms": {
        "field": "data.command",
        "size": 5
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R05 Q2 결과 읽기 — www-data 가 sudo 로 실행하려 한 명령

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수
list	6
/usr/bin/find . -exec /bin/sh ; -quit	1

왜 이걸 보나 — www-data 가 sudo 로 무엇을 하려 했나 — 명령이 곧 의도다 .

Visualize 로 같은 표

```
Split rows: Terms data.command size 5
```

R05 Q3 집계 쿼리 — mediforum 이벤트 1 시간 단위 — 0 건 구간만

```
POST purple-r05/_search
{
  "size": 0,
  "query": {
    "term": {
      "agent.name": "mediforum"
    }
  },
  "aggs": {
    "t": {
      "date_histogram": {
        "field": "timestamp",
        "fixed_interval": "1h",
        "time_zone": "+09:00",
        "format": "MM-dd HH:mm",
        "min_doc_count": 0
      },
      "aggs": {
        "zero": {
          "bucket_selector": {
            "buckets_path": {
              "c": "_count"
            },
            "script": "params.c == 0"
          }
        }
      }
    }
  }
}
```

집계 기법 : Date Histogram(시간) · bucket_selector(조건) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R05 Q3 결과 읽기 — mediforum 이벤트 1 시간 단위 — 0 건 구간만

결과 (kt66 실제 적재 · 기준일 2026-11-01)

key_as_string	건수
10-30 01:00	0
10-30 02:00	0

왜 이걸 보나 — 대량 로그 서버가 1 시간 동안 0 건이면 장애이거나 , 누가 에이전트를 껐다 .

Visualize 로 같은 표

Split rows: Date Histogram timestamp 간격 1h → 조건 거르기 (bucket_selector) — Visualize 에는 없음 → DSL · 모니터로

R05 Q4 집계 쿼리 — 실행 파일 경로 — /tmp · /dev/shm 에서 실행된 것

```
POST purple-r05/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "auditd"
          }
        }
      ],
      "should": [
        {
          "prefix": {
            "data.audit.exe": "/tmp/"
          }
        },
        {
          "prefix": {
            "data.audit.exe": "/dev/shm/"
          }
        }
      ],
      "minimum_should_match": 1
    }
  },
  "aggs": {
    "exe": {
      "terms": {
        "field": "data.audit.exe",
        "size": 5
      },
      "aggs": {
        "u": {
          "terms": {
            "field": "data.audit.auid",
            "size": 1
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter).
size:0 = 원문 로그는 안 가져오고 집계 숫자만

R05 Q4 결과 읽기 — 실행 파일 경로 — /tmp · /dev/shm 에서 실행된 것

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
/dev/shm/[kworker/u8:2]	root	91

왜 이걸 보나 — /tmp·/dev/shm 에서 실행된 파일 — 디스크에 오래 남기지 않으려는 흔적 .

Visualize 로 같은 표

```
Split rows: Terms data.audit.exe size 5 →
Split rows: Terms data.audit.auid size 1
```

R05 Q5 집계 쿼리 — 파일 삭제 (FIM 553) 경로

```
POST purple-r05/_search
{
  "size": 0,
  "query": {
    "term": {
      "rule.id": "553"
    }
  },
  "aggs": {
    "p": {
      "terms": {
        "field": "syscheck.path",
        "size": 8
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter).
size:0 = 원문 로그는 안 가져오고 집계 숫자만

R05 · Terms(버킷)

R05 Q5 결과 읽기 — 파일 삭제 (FIM 553) 경로

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수
/var/log/apache2/adminconsole_access.log.8.gz	90
/var/log/apache2/aicompanion_access.log.8.gz	90
/var/log/apache2/govportal_access.log.8.gz	90
/var/log/apache2/juiceshop_access.log.8.gz	90
/var/log/apache2/mediforum_access.log.8.gz	90
/var/log/apache2/neobank_access.log.8.gz	90
/home/www-data/.bash_history	1
/root/.bash_history	1

왜 이걸 보나 — auth.log·bash_history 삭제는 ' 지우는 행위 ' 자체가 남는다 (FIM 553).

Visualize 로 같은 표

```
Split rows: Terms syscheck.path size 8
```

R05 Q6 집계 쿼리 — mediforum 의 root·www-data 명령 (auditd) — 시간순 첫 10 줄

```
POST purple-r05/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "agent.name": "mediforum"
          }
        },
        {
          "term": {
            "decoder.name": "auditd"
          }
        },
        {
          "terms": {
            "data.audit.auid": [
              "root",
              "www-data"
            ]
          }
        }
      ],
      "must_not": [
        {
          "term": {
            "data.audit.exe": "/usr/bin/php"
          }
        }
      ]
    }
  },
  "aggs": {
    "t": {
      "date_histogram": {
        "field": "timestamp",
        "fixed_interval": "1m",
        "time_zone": "+09:00",
        "format": "MM-dd HH:mm",
        "min_doc_count": 1
      },
      "aggs": {
        "c": {
          "terms": {
            "field": "data.audit.command",
            "size": 3
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Date Histogram(시간) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R05 Q6 결과 읽기 — mediforum 의 root·www-data 명령 (auditd) — 시간순 첫 10 줄 (1/2)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

날짜	값
10-03 03:00	systemctl stop wazuh-agent
10-14 03:03	systemctl stop wazuh-agent
10-23 02:02	systemctl stop wazuh-agent
10-30 00:40	sudo -l
10-30 00:41	/bin/sh

R05 Q6 결과 읽기 — mediforum 의 root·www-data 명령 (auditd) — 시간순 첫 10 줄 (2/2)

날짜	값
10-30 00:41	find . -exec /bin/sh ; -quit
10-30 00:41	sudo -l
10-30 00:43	[kworker/u8:2]

왜 이걸 보나 — root·www-data 명령을 시간순으로 — 권한상승 전후가 한 줄로 이어진다 .

Visualize 로 같은 표

```
Split rows: Date Histogram timestamp 간격 1m →
Split rows: Terms data.audit.command size 3
```

R05 모니터 — 집계를 경보로

경보는 '한 줄'이 아니라 '조건을 넘는 집계 결과'로 울린다 — bucket_selector 로 거른 뒤 OpenSearch Alerting 모니터로 자동화한다 .

모니터

대량 로그 서버 4 대 중 1 시간 동안 이벤트 0 건이 된 구간 — 트리거 `ctx.results[0].aggregations.ag.buckets.stream().anyMatch(b -> b.t.buckets.size() > 0)`

지금 걸리는 대상

구분	key_as_string	건수
mediforum	10-30 01:00	0
mediforum	10-30 02:00	0

트리거

```
ctx.results[0].aggregations.ag.buckets.stream().anyMatch(b -> b.t.buckets.size() > 0)
```

R05 규칙 팩 — 같은 판단을 자동화

집계로 '찾은' 판단을 서명 (Suricata·ModSecurity)· 상관 (Wazuh)·Sigma·osquery 규칙으로 바꿔 자동 탐지한다 .

도구	ID	내용
Wazuh	190501 (L12)	PURPLE R05: 웹 서비스 계정 $(srcuser) 의 sudo 사용 — 권한상승 시도
Wazuh	190502 (L10)	PURPLE R05: 10 분에 sudo 실패 3 회 이상 $(srcuser) [빈도 3/600s]
Wazuh	190503 (L10)	PURPLE R05: 대량 로그 서버 에이전트 연결 끊김 — 로그 공백 (방어회피) 가능성
Sigma	단건	PURPLE R05 Web Service Account sudo
osquery	purple_r05_fake_kthread	R05: 커널 스레드처럼 대괄호 이름인데 실행 파일 경로가 있는 프로세스 (위장)
osquery	purple_r05_shm_exec	R05: 메모리 · 임시 경로 실행 또는 삭제된 실행 파일
osquery	purple_r05_empty_logs	R05: 비워진 인증 로그 · 히스토리
osquery	purple_r05_wazuh_agent	R05: wazuh-agent 동작 상태
Sysmon	ProcessCreate	rules/r05/sysmon.xml

R05 대응 — 그래서 무엇을 하나

대응

190501(서비스 계정 sudo)·190503(에이전트 끊김) 은 즉시 담당자 호출 . 공백 구간은 다른 센서 (IPS·FW) 로 메워 그 시간의 행위를 복원한다 .

생각해 볼 것

- 서명 (한 줄)· 상관 (분 ~ 일)· 집계 (전체 기간) 중 이 라운드의 공격을 처음 드러낸 것은 무엇인가 ?
- 정상 99.9% 안에서 임계값을 어디에 두면 오탐이 0 이 되는가 ? (미션 2~4 의 분포로 근거를 댄다)
- 공격자가 기간을 두 배로 늘리면 (--days 180) 어떤 집계가 약해지고 어떤 집계가 강해지는가 ?

R05 한 장 정리

결정적 집계	1 시간 버킷 중 0 건 구간 · sudo 사용자 × 결과
찾은 것	mediforum 01~02 시 0 건 , www-data 의 sudo, /dev/shm/[kworker] 91 회
규칙	Wazuh 서비스 계정 sudo · 에이전트 끊김 · osquery 위장 프로세스

분산 · 장기 공격은 서명 · 상관에서 0 건이 정상 — 그래서 집계가 먼저다 .

R06 · 자격증명 공격

자격증명 접근 — 분산 대입과 피싱

IP 당 1~2 번뿐인 분산 대입은 IP 별 집계로 안 보인다 — 계정별 '서로 다른 IP 수'로 뒤집어 본다

총 2,445,007 건 · 공격 3,637 건 · 정상(배경 포함) 99.851%

R06 시나리오 — 무엇이 일어났나

R06 자격증명 접근 — IP 당 1~2 번뿐인 분산 대입 , 낯선 발신 도메인 , 두 번째 나라에서의 로그인 .

Red — 공격 (로그로만 재현 , 실제 공격 없음)

- 1) 웹메일 비밀번호 분산 대입 (spray): 1,200 개 IP(대부분 국내) 가 D-60~D-1 에 걸쳐 1~2 번씩 — 3 개 계정 성공 → 몇 주에 걸쳐 다른 출구 IP 로 재로그인
- 2) 피싱 : 유사 도메인에서 직원 40 명에게 3 분 안에 발송 → 1 명 (lee.yuna) 계정이 해외에서 로그인 · 메일함 열람

Blue — 집계로 찾기

- IP 별 실패 (소용없음) → 계정별 실패 IP 수 → 계정별 외부 성공 IP 수 → 해외 성공 → 희귀 발신 도메인 → 메일함 열람량

R06 데이터 — 정상의 모양부터 (1/2)

총 2,445,007 건 · 공격 3,637 건 · 정상 (배경 포함) 99.851%

기간 기본 90 일 (D-90 ~ D-1). 기준일 2026-11-01 이면 정답 키와 숫자가 같다

인덱스 `purple-r06` · 인덱스 패턴 `purple-*` · 시간 필드 `timestamp`

엔드포인트 — 시스템마다 가상 IP

시스템	IP
juice.kt66.lab	`198.51.100.81`
dvwa.kt66.lab	`198.51.100.82`
neobank.kt66.lab	`198.51.100.83`

R06 데이터 — 정상의 모양부터 (2/2)

시스템	IP
govportal.kt66.lab	198.51.100.84
mediforum.kt66.lab	198.51.100.85
admin.kt66.lab	198.51.100.86
ai.kt66.lab	198.51.100.87
webmail.kt66.lab	198.51.100.26
bastion	10.20.30.201
KT66-WIN-01	10.20.70.10

R06 Q1 집계 쿼리 — 웹메일 로그인 실패 — IP 별 상위 5 (IP 당 횟수)

```
POST purple-r06/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "data.app": "webmail"
          }
        },
        {
          "term": {
            "data.result": "fail"
          }
        }
      ]
    }
  },
  "aggs": {
    "by_ip": {
      "terms": {
        "field": "data.srcip",
        "size": 5
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter).
size:0 = 원문 로그는 안 가져오고 집계 숫자만

R06 Q1 결과 읽기 — 웹메일 로그인 실패 — IP 별 상위 5 (IP 당 횟수)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수
10.20.70.94	4
10.20.70.198	3
10.20.70.201	3
10.20.70.101	2
10.20.70.11	2

왜 이걸 보나 — IP 별 실패 상위는 내부 사용자의 오타 (3~4 건) — 분산 대입 IP 는 1~2 건이라 상위에 없다 . IP 기준 임계값 (5 회) 은 아무것도 못 잡는다 .

Visualize 로 같은 표

```
Split rows: Terms data.srcip size 5
```

R06 Q2 집계 쿼리 — 웹메일 로그인 실패 — 계정별 서로 다른 출발 IP 수 (상위 5)

```
POST purple-r06/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "data.app": "webmail"
          }
        },
        {
          "term": {
            "data.result": "fail"
          }
        }
      ]
    }
  },
  "aggs": {
    "by_user": {
      "terms": {
        "field": "data.srcuser",
        "size": 5,
        "order": {
          "ips": "desc"
        }
      },
      "aggs": {
        "ips": {
          "cardinality": {
            "field": "data.srcip"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R06 Q2 결과 읽기 — 웹메일 로그인 실패 — 계정별 서로 다른 출발 IP 수 (상위 5)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	서로 다른 IP 수
jung.jiho	14	14
kang.juwon	14	14
lim.jimin	15	14
lim.jiwoo	14	14
lim.suah	14	14

왜 이걸 보나 — 축을 뒤집는다 : 계정별 ' 서로 다른 출발 IP 수 '. 정상 계정은 1~2, 표적 계정은 수십 .

Visualize 로 같은 표

Split rows: Terms data.srcuser size 5 · 정렬 ips desc →
Metric: Unique Count data.srcip

R06 Q3 집계 쿼리 — 웹메일 로그인 성공 — 계정별 서로 다른 '외부' IP 수 (2 이상)

```
POST purple-r06/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "data.app": "webmail"
          }
        },
        {
          "term": {
            "data.result": "success"
          }
        }
      ],
      "must_not": [
        {
          "prefix": {
            "data.srcip": "10."
          }
        }
      ]
    }
  },
  "aggs": {
    "by_user": {
      "terms": {
        "field": "data.srcuser",
        "size": 300,
        "order": {
          "ips": "desc"
        }
      },
      "aggs": {
        "ips": {
          "cardinality": {
            "field": "data.srcip"
          }
        },
        "two": {
          "bucket_selector": {
            "buckets_path": {
              "n": "ips"
            },
            "script": "params.n >= 2"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · bucket_selector(조건) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R06 Q3 결과 읽기 — 웹메일 로그인 성공 — 계정별 서로 다른 '외부' IP 수 (2 이상)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	서로 다른 IP 수
jung.dohyun	6	5
kang.seoah	6	5
choi.jiho	5	4
lee.yuna	4	2

왜 이걸 보나 — 성공한 외부 IP 가 2 곳 이상인 계정 — 본인 + 누군가 .

Visualize 로 같은 표

Split rows: Terms data.srcuser size 300 · 정렬 ips desc → Metric: Unique Count data.srcip → 조건 거르기 (bucket_selector) — Visualize 에는 없음 → DSL·모니터로

R06 Q4 집계 쿼리 — 웹메일 로그인 성공 — 국외 출발지

```
POST purple-r06/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "data.app": "webmail"
          }
        },
        {
          "term": {
            "data.result": "success"
          }
        },
        {
          "exists": {
            "field": "GeoLocation.country_name"
          }
        }
      ],
      "must_not": [
        {
          "term": {
            "GeoLocation.country_name": "Republic of Korea"
          }
        }
      ]
    }
  },
  "aggs": {
    "by_user": {
      "terms": {
        "field": "data.srcuser",
        "size": 5
      },
      "aggs": {
        "cc": {
          "terms": {
            "field": "GeoLocation.country_name",
            "size": 2
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter).
size:0 = 원문 로그는 안 가져오고 집계 숫자만

R06 Q4 결과 읽기 — 웹메일 로그인 성공 — 국외 출발지

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
lee.yuna	Netherlands	4
choi.jiho	United States	1
jung.dohyun	United States	1

왜 이걸 보나 — 국외 출발지 성공 — GeoLocation 집계 한 번이면 끝난다 .

Visualize 로 같은 표

```
Split rows: Terms data.srcuser size 5 → Split rows: Terms GeoLocation.country_name size 2
```

R06 Q5 집계 쿼리 — 수신 메일 (전달됨) — 발신 도메인 중 드문 것 (적은 순 3) · 수신자 수

```
POST purple-r06/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "data.direction": "in"
          }
        },
        {
          "term": {
            "data.status": "sent"
          }
        }
      ]
    }
  },
  "aggs": {
    "dom": {
      "terms": {
        "field": "data.from_domain",
        "size": 3,
        "order": {
          "_count": "asc"
        }
      },
      "aggs": {
        "rcpt": {
          "cardinality": {
            "field": "data.to"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R06 Q5 결과 읽기 — 수신 메일 (전달됨) — 발신 도메인 중 드문 것 (적은 순 3) · 수신자 수

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	rcpt
kt66-lab.help	40	40
partner-corp.co.kr	2878	240
naver.com	2972	240

왜 이걸 보나 — 발신 도메인을 적은 순으로 — 한 번도 안 보던 유사 도메인이 3 분 안에 40 명에게 .

Visualize 로 같은 표

Split rows: Terms data.from_domain size 3 · 정렬 _count asc → Metric: Unique Count data.to

R06 Q6 집계 쿼리 — 웹메일 — 서로 다른 메일을 가장 많이 연 IP (상위 5)

```
POST purple-r06/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "data.vhost": "webmail.kt66.lab"
          }
        },
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        }
      ]
    }
  },
  "aggs": {
    "by_ip": {
      "terms": {
        "field": "data.srcip",
        "size": 5,
        "order": {
          "urls": "desc"
        }
      },
      "aggs": {
        "urls": {
          "cardinality": {
            "field": "data.url"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R06 Q6 결과 읽기 — 웹메일 — 서로 다른 메일을 가장 많이 연 IP (상위 5)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	고유 URL 수
102.225.118.252	323	321
10.20.70.196	118	48
10.20.70.43	112	47
10.20.70.30	111	45
10.20.70.32	131	45

왜 이걸 보나 — 서로 다른 메일 (_uid) 을 가장 많이 연 IP — 사람은 수백 통을 몇 분에 열지 않는다 .

Visualize 로 같은 표

```
Split rows: Terms data.srcip size 5 · 정렬 urls desc →
Metric: Unique Count data.url
```

R06 모니터 — 집계를 경보로 (1/2)

경보는 '한 줄'이 아니라 '조건을 넘는 집계 결과'로 울린다 — bucket_selector 로 거른 뒤 OpenSearch Alerting 모니터로 자동화한다.

모니터

외부 IP 2 곳 이상에서 로그인에 성공한 웹메일 계정 — 트리거 `ctx.results[0].aggregations.by_user.buckets.size() > 0`

지금 걸리는 대상

값	건수	서로 다른 IP 수
jung.dohyun	6	5
kang.seoah	6	5
choi.jiho	5	4
lee.yuna	4	2

R06 모니터 — 집계를 경보로 (2/2)

트리거	`ctx.results[0].aggregations.by_user.buckets.size() > 0`

R06 규칙 팩 — 같은 판단을 자동화 (1/3)

집계로 '찾은' 판단을 서명 (Suricata·ModSecurity)· 상관 (Wazuh)·Sigma·osquery 규칙으로 바꿔 자동 탐지한다 .

도구	ID	내용
Suricata	9606001	PURPLE R06 webmail login failure (marker for aggregation)
Suricata	9606002	PURPLE R06 mailbox bulk read - 100 message views in 10 min
ModSecurity	90602	PURPLE R06 account %{tx.r06_user} locked - %{resource.fail} failures from many IPs

R06 규칙 팩 — 같은 판단을 자동화 (2/3)

도구	ID	내용
Wazuh	190601 (L3)	PURPLE R06: 웹메일 로그인 실패 $(srcuser) from $(srcip)
Wazuh	190602 (L3)	PURPLE R06: 웹메일 로그인 성공 $(srcuser) from $(srcip)
Wazuh	190603 (L10)	PURPLE R06: 한 계정 $(srcuser) 을 일주일에 서로 다른 IP 5 곳이 실패 — 분산 대입 (spray) [빈도 5/604800s]
Wazuh	190604 (L13)	PURPLE R06: 분산 대입 대상 계정 $(srcuser) 의 로그인 성공 — 계정 탈취 의심 [순서 604800s]

R06 규칙 팩 — 같은 판단을 자동화 (3/3)

도구	ID	내용
Wazuh	190605 (L6)	PURPLE R06: 회사 도메인을 흉내 낸 발신 도메인 $(from)
Wazuh	190606 (L12)	PURPLE R06: 유사 도메인 발신자가 10 분에 20 명 이상에게 발송 — 피싱 캠페인 [빈도 20/600s]
Sigma	단건	PURPLE R06 Webmail Login Failure
Sigma	상관	PURPLE R06 Password Spray - 5 sources per account per week
Sigma	단건	PURPLE R06 Lookalike Sender Domain

R06 대응 — 그래서 무엇을 하나

대응

190604(분산 대입 대상 계정 로그인 성공) → 계정 세션 폐기 · 비밀번호 재설정 ·MFA 강제 . IP 차단은 1,200 개 IP 에 소용없다 . 190606(피싱) → 발신 도메인 차단 · 수신함 회수 .

생각해 볼 것

- 서명 (한 줄)· 상관 (분 ~ 일)· 집계 (전체 기간) 중 이 라운드의 공격을 처음 드러낸 것은 무엇인가 ?
- 정상 99.9% 안에서 임계값을 어디에 두면 오탐이 0 이 되는가 ? (미션 2~4 의 분포로 근거를 댄다)
- 공격자가 기간을 두 배로 늘리면 (--days 180) 어떤 집계가 약해지고 어떤 집계가 강해지는가 ?

R06 한 장 정리

결정적 집계	계정별 서로 다른 실패 IP · 성공 외부 IP 수
찾은 것	IP 당 실패 최대 4 회 · 탈취 계정 3 개 + 피싱 1 명 · 유사 도메인 40 명
규칙	ModSec 계정 카운터 · Wazuh same_srcuser + different_srcip · Sigma value_count

분산 · 장기 공격은 서명 · 상관에서 0 건이 정상 — 그래서 집계가 먼저다 .

R07 · 횡적 이동

내부 이동 — 계정 하나 , 서버 여러 대

계정 하나가 10 분 안에 서버 여러 대로 — 계정 × 시간 버킷 × 서로 다른 호스트 수

총 2,444,140 건 · 공격 135 건 · 정상 (배경 포함) 99.994%

R07 시나리오 — 무엇이 일어났나

R07 내부 이동 — 관리자 계정 하나가 10 분 안에 서버 여러 대로 퍼진다 .

Red — 공격 (로그로만 재현 , 실제 공격 없음)

- 1) D-45~D-4: 새벽에 해외 IP 로 bastion 로그인 후 서버 1 대씩 ' 둘러보기 '(실제 로그 재방문 패턴)
- 2) D-3 01:20: bastion → 서버존 포트 스캔 → 8 분 안에 서버 6 대 SSH, dvwa 실패
- 3) neobank → KT66-WIN-01 네트워크 로그온 (유형 3) → 서비스 실행 → 계정 생성 · 관리자 그룹 추가

Blue — 집계로 찾기

- 계정 ×10 분 × 호스트 수 → bastion 해외 로그인 → 동서 스캔 → 로그온 유형 → 그룹 변경 → 타임라인

R07 데이터 — 정상의 모양부터 (1/2)

총 2,444,140 건 · 공격 135 건 · 정상 (배경 포함) 99.994%

기간	기본 90 일 (D-90 ~ D-1). 기준일 2026-11-01 이면 정답 키와 숫자가 같다
인덱스	`purple-r07` · 인덱스 패턴 `purple-*` · 시간 필드 `timestamp`

엔드포인트 — 시스템마다 가상 IP

시스템	IP
juice.kt66.lab	`198.51.100.81`
dvwa.kt66.lab	`198.51.100.82`
neobank.kt66.lab	`198.51.100.83`

R07 데이터 — 정상의 모양부터 (2/2)

시스템	IP
govportal.kt66.lab	198.51.100.84
mediforum.kt66.lab	198.51.100.85
admin.kt66.lab	198.51.100.86
ai.kt66.lab	198.51.100.87
webmail.kt66.lab	198.51.100.26
bastion	10.20.30.201
KT66-WIN-01	10.20.70.10

R07 Q1 집계 쿼리 — bastion 경유 서버 로그인 — 계정 × 10 분 × 서로 다른 서버 수 (4 대 이상만)

```
POST purple-r07/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "rule.id": "5715"
          }
        },
        {
          "term": {
            "data.srcip": "10.20.30.201"
          }
        }
      ]
    }
  },
  "aggs": {
    "u": {
      "terms": {
        "field": "data.srcuser",
        "size": 20
      },
      "aggs": {
        "t": {
          "date_histogram": {
            "field": "timestamp",
            "fixed_interval": "10m",
            "time_zone": "+09:00",
            "format": "MM-dd HH:mm",
            "min_doc_count": 1
          },
          "aggs": {
            "hosts": {
              "cardinality": {
                "field": "agent.name"
              }
            },
            "many": {
              "bucket_selector": {
                "buckets_path": {
                  "h": "hosts"
                },
                "script": "params.h >= 4"
              }
            }
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · Date Histogram(시간) · bucket_selector(조건) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R07 Q1 결과 읽기 — bastion 경유 서버 로그인 — 계정 × 10 분 × 서로 다른 서버 수 (4 대 이상만)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	key_as_string	고유 vhost 수
kim.minjun	10-29 01:20	4

왜 이걸 보나 — 관리자도 하루에 여러 서버에 들어간다 . 다른 것은 속도 — 10 분에 4 대 이상 .

Visualize 로 같은 표

Split rows: Terms data.srcuser size 20 → Split rows: Date Histogram timestamp 간격 10m → Metric: Unique Count agent.name → 조건 거르기 (bucket_selector) — Visualize 에는 없음 → DSL·모니터로

R07 Q2 집계 쿼리 — bastion 로그인 성공 — 외부 출발지 국가별 계정

```
POST purple-r07/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "agent.name": "bastion"
          }
        },
        {
          "term": {
            "rule.id": "5715"
          }
        },
        {
          "exists": {
            "field": "GeoLocation.country_name"
          }
        }
      ]
    }
  },
  "aggs": {
    "cc": {
      "terms": {
        "field": "GeoLocation.country_name",
        "size": 4
      },
      "aggs": {
        "u": {
          "terms": {
            "field": "data.srcuser",
            "size": 3
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R07 Q2 결과 읽기 — bastion 로그인 성공 — 외부 출발지 국가별 계정

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
Republic of Korea	kim.yejun	51
Republic of Korea	kim.seojun	50
Republic of Korea	kim.jimin	47
Russia	kim.minjun	4

왜 이걸 보나 — bastion 에 외부 IP 가 직접 붙었다 — VPN 없이 들어온 관리자 계정 .

Visualize 로 같은 표

```
Split rows: Terms GeoLocation.country_name size 4
→ Split rows: Terms data.srcuser size 3
```

R07 Q3 집계 쿼리 — 서버존 (10.20.40.x) 으로 들어온 동서 연결 — 출발지별 포트 · 목적지 수

```
POST purple-r07/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "data.event_type": "flow"
          }
        },
        {
          "prefix": {
            "data.dest_ip": "10.20.40."
          }
        }
      ]
    }
  },
  "aggs": {
    "src": {
      "terms": {
        "field": "data.src_ip",
        "size": 5,
        "order": {
          "ports": "desc"
        }
      },
      "aggs": {
        "ports": {
          "cardinality": {
            "field": "data.dest_port"
          }
        },
        "dsts": {
          "cardinality": {
            "field": "data.dest_ip"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R07 Q3 결과 읽기 — 서버존 (10.20.40.x) 으로 들어온 동서 연결 — 출발지별 포트 · 목적지 수

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	고유 포트 수	고유 목적지 수
10.20.30.201	105	15	7
10.20.32.51	8304	2	6

왜 이걸 보나 — 서버존으로 들어온 동서 연결 — 출발지 하나가 포트 15 개 × 서버 7 대 .

Visualize 로 같은 표

Split rows: Terms data.src_ip size 5 · 정렬 ports desc → Metric: Unique Count data.dest_port → Metric: Unique Count data.dest_ip

R07 Q4 집계 쿼리 — KT66-WIN-01 로그온 성공 (4624) — 유형 × 출발 IP

```
POST purple-r07/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "agent.name": "KT66-WIN-01"
          }
        },
        {
          "term": {
            "data.win.system.eventID": "4624"
          }
        }
      ]
    }
  },
  "aggs": {
    "lt": {
      "terms": {
        "field": "data.win.eventdata.logonType"
        ,
        "size": 4
      },
      "aggs": {
        "ip": {
          "terms": {
            "field": "data.win.eventdata
              .ipAddress",
            "size": 2,
            "missing": "-"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R07 Q4 결과 읽기 — KT66-WIN-01 로그온 성공 (4624) — 유형 × 출발 IP

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
5	-	2199
2	-	90
3	10.20.40.83	3

왜 이걸 보나 — PC 에 '네트워크 로그온 (유형 3)' 이 서버에서 왔다 — 방향이 거꾸로다 .

Visualize 로 같은 표

```
Split rows: Terms data.win.eventdata.logonType
size 4 → Split rows: Terms
data.win.eventdata.ipAddress size 2
```

R07 Q5 집계 쿼리 — KT66-WIN-01 레벨 8 이상 경보

```
POST purple-r07/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "agent.name": "KT66-WIN-01"
          }
        },
        {
          "range": {
            "rule.level": {
              "gte": 8
            }
          }
        }
      ]
    }
  },
  "aggs": {
    "r": {
      "terms": {
        "field": "rule.description",
        "size": 4
      },
      "aggs": {
        "u": {
          "terms": {
            "field": "data.win.eventdata
              .targetUserName",
            "size": 1
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter).
size:0 = 원문 로그는 안 가져오고 집계 숫자만

R07 Q5 결과 읽기 — KT66-WIN-01 레벨 8 이상 경보

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
Administrators Group Changed	svc_backup	1
User account enabled or created	svc_backup	1

왜 이걸 보나 — 그 PC 의 레벨 8+ 경보 — 계정 생성 · 관리자 그룹 변경 .

Visualize 로 같은 표

```
Split rows: Terms rule.description size 4 →
Split rows: Terms
data.win.eventdata.targetUserName size 1
```

R07 · Terms(버킷) · Date Histogram(시간) · bucket_selector(조건)

R07 Q6 집계 쿼리 — kim.minjun·svc_backup·neobank 발 로그온 — 10 분 버킷 중 4 건 이상만 , 호스트별

```
POST purple-r07/_search
{
  "size": 0,
  "query": {
    "bool": {
      "should": [
        {
          "term": {
            "data.srcuser": "kim.minjun"
          }
        },
        {
          "term": {
            "data.win.eventdata.ipAddress": "10.20.40.83"
          }
        },
        {
          "term": {
            "data.win.eventdata.targetUserName": "svc_backup"
          }
        }
      ],
      "minimum_should_match": 1
    }
  },
  "aggs": {
    "t": {
      "date_histogram": {
        "field": "timestamp",
        "fixed_interval": "10m",
        "time_zone": "+09:00",
        "format": "MM-dd HH:mm",
        "min_doc_count": 1
      },
      "aggs": {
        "ag": {
          "terms": {
            "field": "agent.name",
            "size": 8
          }
        },
        "busy": {
          "bucket_selector": {
            "buckets_path": {
              "c": "_count"
            },
            "script": "params.c >= 4"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Date Histogram(시간) · bucket_selector(조건) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R07 Q6 결과 읽기 — kim.minjun·svc_backup·neobank 발 로그온 — 10 분 버킷 중 4 건 이상만 , 호스트별 (1/2)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

날짜	값	건수
10-29 01:20	govportal	2
10-29 01:20	juiceshop	2
10-29 01:20	neobank	2
10-29 01:20	bastion	1
10-29 01:20	mediforum	1
10-29 01:30	KT66-WIN-01	3
10-29 01:30	dvwa	3

R07 Q6 결과 읽기 — kim.minjun·svc_backup·neobank 발 로그온 — 10 분 버킷 중 4 건 이상만 , 호스트별 (2/2)

날짜	값	건수
10-29 01:30	adminconsole	2

왜 이걸 보나 — 관련 계정 · 호스트만 10 분 버킷으로 — 확산의 순서가 보인다 .

Visualize 로 같은 표

Split rows: Date Histogram timestamp 간격 10m → Split rows: Terms agent.name size 8 → 조건 거르기 (bucket_selector) — Visualize 에는 없음 → DSL · 모니터로

R07 모니터 — 집계를 경보로

경보는 '한 줄'이 아니라 '조건을 넘는 집계 결과'로 울린다 — bucket_selector 로 거른 뒤 OpenSearch Alerting 모니터로 자동화한다.

모니터

한 계정이 10분 안에 서버 4대 이상 로그인 — 트리거 `ctx.results[0].aggregations.u.buckets.stream().anyMatch(b -> b.t.buckets.size() > 0)`

지금 걸리는 대상

구분	key_as_string	고유 vhost 수
kim.minjun	10-29 01:20	4

트리거

```
ctx.results[0].aggregations.u.buckets.stream().anyMatch(b -> b.t.buckets.size() > 0)
```

R07 규칙 팩 — 같은 판단을 자동화 (1/4)

집계로 '찾은' 판단을 서명 (Suricata·ModSecurity)· 상관 (Wazuh)·Sigma·osquery 규칙으로 바꿔 자동 탐지한다 .

도구	ID	내용
Suricata	9607001	PURPLE R07 east-west port sweep from bastion
Suricata	9607002	PURPLE R07 server zone to user PC SMB - lateral movement
Suricata	9607003	PURPLE R07 bastion SSH fan-out - 5 servers in 10 min
Wazuh	190701 (L3)	PURPLE R07: bastion 경유 SSH 로그인 $(dstuser)

R07 규칙 팩 — 같은 판단을 자동화 (2/4)

도구	ID	내용
Wazuh	190702 (L12)	PURPLE R07: 한 계정 $(dstuser) 이 10 분 안에 bastion 경유로 서버 4 대 이상 로그인 — 내부 확산 [빈도 4/600s]
Wazuh	190703 (L12)	PURPLE R07: 외부 IP $(srcip) 에서 bastion 직접 로그인 $(dstuser)
Wazuh	190704 (L10)	PURPLE R07: 서버존에서 사용자 PC 로 네트워크 로그온 (유형 3) $(win.eventdata.targetUserName)
Wazuh	190705 (L13)	PURPLE R07: 원격 서비스 실행 (PsExec 계열) $ (win.eventdata.newProcessName)

R07 규칙 팩 — 같은 판단을 자동화 (3/4)

도구	ID	내용
Wazuh	190706 (L15)	PURPLE R07: 서버발 네트워크 로그온 15 분 안에 관리자 그룹 변경 — 내부 이동 후 지속성 [순서 900s]
Sigma	단건	PURPLE R07 SSH Login via Bastion
Sigma	상관	PURPLE R07 One Account Fans Out (4 logins in 10 min)
osquery	purple_r07_ssh_sources	R07: bastion 이 아닌 곳에서 들어온 SSH 로그인 (서버 → 서버)
osquery	purple_r07_outbound_ssh	R07: 서버에서 다른 서버로 나가는 SSH
Sysmon	ProcessCre	rules/r07/sysmon.xml

R07 규칙 팩 — 같은 판단을 자동화 (4/4)

도구	ID	내용
Sysmon	NetworkConnect	rules/r07/sysmon.xml

R07 대응 — 그래서 무엇을 하나

대응

190702·190706 → kim.minjun 세션 강제 종료 · 비밀번호 재설정 , svc_backup 비활성 · 관리자 그룹 원복 . 190703 → bastion 에서 외부 IP 1 시간 차단 (firewall-drop local).

생각해 볼 것

- 서명 (한 줄)· 상관 (분 ~ 일)· 집계 (전체 기간) 중 이 라운드의 공격을 처음 드러낸 것은 무엇인가 ?
- 정상 99.9% 안에서 임계값을 어디에 두면 오탐이 0 이 되는가 ? (미션 2~4 의 분포로 근거를 댄다)
- 공격자가 기간을 두 배로 늘리면 (--days 180) 어떤 집계가 약해지고 어떤 집계가 강해지는가 ?

R07 한 장 정리

결정적 집계	계정 × 10 분 × 서로 다른 서버 수 (4 대 이상)
찾은 것	kim.minjun 01:20 서버 4 대 · bastion 포트 15 개 × 7 대 · PC 관리자 그룹 변경
규칙	Suricata 동서 스캔 · Wazuh same_user 빈도 · 로그온 유형 3 → 그룹 변경 순서

분산 · 장기 공격은 서명 · 상관에서 0 건이 정상 — 그래서 집계가 먼저다 .

R08 · C2· 유출

C2· 유출 — 규칙성과 볼륨

석 달 내내 한 시간마다 같은 곳 , 이름이 긴 DNS 질의 수백 개 , 새벽의 대용량 업로드 — 규칙성과 볼륨

총 2,447,143 건 · 공격 3,273 건 · 정상 (배경 포함) 99.866%

R08 시나리오 — 무엇이 일어났나

R08 C2· 유출 — 석 달 내내 한 시간마다 같은 곳 , 이름이 긴 DNS 질의 수백 개 , 새벽의 대용량 업로드 .

Red — 공격 (로그로만 재현 , 실제 공격 없음)

- 1) HTTPS 비콘 : D-80 부터 1 시간 (±25%) 간격 — 사용자가 없는 밤 · 주말에도
- 2) 비표준 포트 백업 채널 8443: 실제 로그 재방문 패턴으로 드문드문
- 3) DNS 터널 : 서브도메인에 데이터를 실은 TXT 질의 — 세 번의 새벽 (실제 로그 시간대 분포)
- 4) 유출 : D-1 새벽 파일 공유 서비스로 300~800MB 업로드 6 회

Blue — 집계로 찾기

- 내부 출발지별 흐름 → 감염 PC 목적지 → 일별 · 시간대 규칙성 → 도메인별 서브도메인 수 → 업로드 합계 → 포트 분포

R08 데이터 — 정상의 모양부터 (1/2)

총 2,447,143 건 · 공격 3,273 건 · 정상 (배경 포함) 99.866%

기간

기본 90 일 (D-90 ~ D-1). 기준일 2026-11-01 이면 정답 키와 숫자가 같다

인덱스

`purple-r08` · 인덱스 패턴 `purple-*` · 시간 필드 `timestamp`

엔드포인트 — 시스템마다 가상 IP

시스템	IP
juice.kt66.lab	`198.51.100.81`
dvwa.kt66.lab	`198.51.100.82`
neobank.kt66.lab	`198.51.100.83`

R08 데이터 — 정상의 모양부터 (2/2)

시스템	IP
govportal.kt66.lab	198.51.100.84
mediforum.kt66.lab	198.51.100.85
admin.kt66.lab	198.51.100.86
ai.kt66.lab	198.51.100.87
webmail.kt66.lab	198.51.100.26
bastion	10.20.30.201
KT66-WIN-01	10.20.70.10

R08 Q1 집계 쿼리 — 사용자존 (10.20.70.x) 출발지별 외부 연결 수 (상위 5)

```
POST purple-r08/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "data.event_type": "flow"
          }
        },
        {
          "prefix": {
            "data.src_ip": "10.20.70."
          }
        }
      ]
    }
  },
  "aggs": {
    "src": {
      "terms": {
        "field": "data.src_ip",
        "size": 5
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter).
size:0 = 원문 로그는 안 가져오고 집계 숫자만

R08 Q1 결과 읽기 — 사용자존 (10.20.70.x) 출발지별 외부 연결 수 (상위 5)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수
10.20.70.10	2479
10.20.70.71	142
10.20.70.207	132
10.20.70.40	124
10.20.70.75	124

왜 이걸 보나 — 사용자존 출발지별 외부 연결 수 — 감염 PC 가 꼭 1 위는 아니다 .

Visualize 로 같은 표

```
Split rows: Terms data.src_ip size 5
```

R08 Q2 집계 쿼리 — KT66-WIN-01(10.20.70.10) 의 목적지 상위 — 포트 · 활동 일수

```
POST purple-r08/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "data.event_type": "flow"
          }
        },
        {
          "term": {
            "data.src_ip": "10.20.70.10"
          }
        }
      ]
    }
  },
  "aggs": {
    "dst": {
      "terms": {
        "field": "data.dest_ip",
        "size": 5
      },
      "aggs": {
        "port": {
          "terms": {
            "field": "data.dest_port",
            "size": 1
          }
        },
        "days": {
          "date_histogram": {
            "field": "timestamp",
            "fixed_interval": "1d",
            "time_zone": "+09:00",
            "min_doc_count": 1
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Date Histogram(시간) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R08 Q2 결과 읽기 — KT66-WIN-01(10.20.70.10) 의 목적지 상위 — 포트 · 활동 일수

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	활동 일수
112.177.128.164	2367	80
195.187.167.4	7	7
195.30.10.79	6	1
1.223.3.44	5	5
103.72.119.101	5	5

왜 이걸 보나 — 목적지별 활동 일수 — 80 일 내내 매일 가는 곳은 업데이트 서버이거나 C2 다 .

Visualize 로 같은 표

Split rows: Terms data.dest_ip size 5 → Split rows: Terms data.dest_port size 1 → Split rows: Date Histogram timestamp 간격 1d

R08 Q3 집계 쿼리 — 1 위 목적지 (112.177.128.164) — 6 시간 버킷 : 밤 · 주말에도 일정한가 (앞 8 개)

```
POST purple-r08/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "data.event_type": "flow"
          }
        },
        {
          "term": {
            "data.dest_ip": "112.177.128.164"
          }
        },
        {
          "term": {
            "data.dest_port": "443"
          }
        }
      ]
    }
  },
  "aggs": {
    "h": {
      "date_histogram": {
        "field": "timestamp",
        "fixed_interval": "6h",
        "time_zone": "+09:00",
        "format": "MM-dd HH:mm",
        "min_doc_count": 1
      }
    }
  }
}
```

집계 기법 : Date Histogram(시간) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R08 · Date Histogram(시간)

R08 Q3 결과 읽기 — 1 위 목적지 (112.177.128.164) — 6 시간 버킷 : 밤 · 주말에도 일정한가 (앞 8 개)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

key_as_string	건수
08-13 12:00	4
08-13 18:00	6
08-14 00:00	6
08-14 06:00	6
08-14 12:00	5
08-14 18:00	6
08-15 00:00	6
08-15 06:00	7

왜 이걸 보나 — 6 시간 버킷 — 사람은 밤에 자고 주말에 쉰다 . 비콘은 안 쉰다 .

Visualize 로 같은 표 Split rows: Date Histogram timestamp 간격 6h

R08 Q4 집계 쿼리 — DNS — 등록 도메인별 서로 다른 질의 이름 수 · 평균 질의 길이 (상위 5)

```
POST purple-r08/_search
{
  "size": 0,
  "query": {
    "term": {
      "decoder.name": "kt66-dns"
    }
  },
  "aggs": {
    "dom": {
      "terms": {
        "field": "data.domain",
        "size": 5,
        "order": {
          "names": "desc"
        }
      },
      "aggs": {
        "names": {
          "cardinality": {
            "field": "data.query"
          }
        },
        "len": {
          "avg": {
            "field": "data.query_len"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · Avg(평균) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R08 · Terms(버킷) · Cardinality(고유 수) · Avg(평균)

R08 Q4 결과 읽기 — DNS — 등록 도메인별 서로 다른 질의 이름 수 · 평균 질의 길이 (상위 5)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	names	len
cdn-sync-analytics.com	900	900	71
google.com	6513	5	15
microsoft.com	3954	3	18
naver.com	3841	3	13
github.com	2677	2	12

왜 이걸 보나 — 도메인별 '서로 다른 질의 이름 수' — 정상 도메인은 수십 , 터널은 수백 · 수천 .

Visualize 로 같은 표

Split rows: Terms data.domain size 5 · 정렬 names desc → Metric: Unique Count data.query → Metric: Average data.query_len

R08 Q5 집계 쿼리 — 내부 → 외부 업로드 합계 (bytes_toserver, MB) 상위 목적지

```
POST purple-r08/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "data.event_type": "flow"
          }
        },
        {
          "prefix": {
            "data.src_ip": "10.20."
          }
        }
      ]
    }
  },
  "aggs": {
    "dst": {
      "terms": {
        "field": "data.dest_ip",
        "size": 5,
        "order": {
          "up": "desc"
        }
      },
      "aggs": {
        "up": {
          "sum": {
            "field": "data.flow.bytes_toserver"
          }
        },
        "srcs": {
          "cardinality": {
            "field": "data.src_ip"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · Sum(합계) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R08 Q5 결과 읽기 — 내부 → 외부 업로드 합계 (bytes_toserver, MB) 상위 목적지

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	up	서로 다른 출발지 수
195.30.10.79	6	3447	1
133.230.135.76	2110	6	7
214.141.49.132	788	4	224
215.246.204.97	821	3	229
103.72.119.101	776	3	226

왜 이걸 보나 — 업로드 합계 (MB) — 평소 KB 단위인 PC 가 새벽에 GB.

Visualize 로 같은 표

Split rows: Terms data.dest_ip size 5 · 정렬 up desc → Metric: Sum data.flow.bytes_toserver → Metric: Unique Count data.src_ip

R08 Q6 집계 쿼리 — 사용자존 외부 연결 — 목적지 포트 분포

```
POST purple-r08/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "data.event_type": "flow"
          }
        },
        {
          "prefix": {
            "data.src_ip": "10.20.70."
          }
        }
      ]
    }
  },
  "aggs": {
    "port": {
      "terms": {
        "field": "data.dest_port",
        "size": 5
      },
      "aggs": {
        "srcs": {
          "cardinality": {
            "field": "data.src_ip"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R08 Q6 결과 읽기 — 사용자존 외부 연결 — 목적지 포트 분포

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	서로 다른 출발지 수
443	26797	240
8443	448	1

왜 이걸 보나 — 목적지 포트 분포 — 443 이 대부분인데 8443 이 끼어 있다 .

Visualize 로 같은 표

```
Split rows: Terms data.dest_port size 5 →
Metric: Unique Count data.src_ip
```

R08 모니터 — 집계를 경보로

경보는 '한 줄'이 아니라 '조건을 넘는 집계 결과'로 울린다 — bucket_selector 로 거른 뒤 OpenSearch Alerting 모니터로 자동화한다.

모니터

서로 다른 서브도메인 200 개 이상을 질의한 도메인 (DNS 터널 후보) — 트리거 `ctx.results[0].aggregations.dom.buckets.size() > 0`

지금 걸리는 대상

값	건수	names
cdn-sync-analytics.com	900	900

트리거

```
ctx.results[0].aggregations.dom.buckets.size() > 0
```

R08 규칙 팩 — 같은 판단을 자동화 (1/4)

집계로 '찾은' 판단을 서명 (Suricata·ModSecurity)· 상관 (Wazuh)·Sigma·osquery 규칙으로 바꿔 자동 탐지한다 .

도구	ID	내용
Suricata	9608001	PURPLE R08 DNS tunnel - 40+ hex char label
Suricata	9608002	PURPLE R08 user zone to external 8443 (non-standard TLS)
Suricata	9608003	PURPLE R08 large upload over TLS (>100MB, stream)
Wazuh	190801 (L5)	PURPLE R08: 16 진수 40 자 이상 서브도메인 질의 $(query) from $(srcip)

R08 규칙 팩 — 같은 판단을 자동화 (2/4)

도구	ID	내용
Wazuh	190802 (L12)	PURPLE R08: 15 분에 긴 서브도메인 질의 100 회 이상 $(srcip) — DNS 터널 [빈도 100/900s]
Wazuh	190803 (L6)	PURPLE R08: 사용자 PC → 외부 8443 흐름 $(dest_ip)
Wazuh	190804 (L10)	PURPLE R08: 하루에 같은 외부 8443 목적지로 10 회 이상 — 백업 C2 채널 [빈도 10/86400s]
Wazuh	190805 (L3)	PURPLE R08: 사용자 PC → 외부 443 흐름

R08 규칙 팩 — 같은 판단을 자동화 (3/4)

도구	ID	내용
Wazuh	190806 (L8)	PURPLE R08: 하루 22 회 이상 같은 PC → 같은 외부 443 — 비콘 후보 (규칙성은 집계로 확인) [빈도 22/86400s]
Sigma	단건	PURPLE R08 Long Hex Subdomain Query
Sigma	상관	PURPLE R08 DNS Tunnel - 100 queries in 15 min
osquery	purple_r08_8443	R08: 비표준 포트 외부 연결 프로세스 (Windows/Linux 공용)
osquery	purple_r08_dns_cache	R08: (Windows) DNS 캐시의 긴 이름
Sysmon	DnsQuery	rules/r08/sysmon.xml

R08 규칙 팩 — 같은 판단을 자동화 (4/4)

도구	ID	내용
Sysmon	NetworkConnect	rules/r08/sysmon.xml

R08 대응 — 그래서 무엇을 하나

대응

C2· 유출 목적지를 kt66-fw egress 블록리스트 (nft set) 에 넣고 감염 PC(10.20.70.10) 격리 . DNS 터널 도메인은 DNS 싱크홀 .

생각해 볼 것

- 서명 (한 줄)· 상관 (분 ~ 일)· 집계 (전체 기간) 중 이 라운드의 공격을 처음 드러낸 것은 무엇인가 ?
- 정상 99.9% 안에서 임계값을 어디에 두면 오탐이 0 이 되는가 ? (미션 2~4 의 분포로 근거를 댄다)
- 공격자가 기간을 두 배로 늘리면 (--days 180) 어떤 집계가 약해지고 어떤 집계가 강해지는가 ?

R08 한 장 정리

결정적 집계	목적지별 활동 일수 · 도메인별 서로 다른 질의 수 · 업로드 합계
찾은 것	80 일 내내 같은 곳 2,367 회 · 서브도메인 900 개 · 새벽 3.4GB
규칙	Suricata 긴 DNS 라벨 ·8443 · Wazuh 15 분 100 회 · Sysmon DnsQuery

분산 · 장기 공격은 서명 · 상관에서 0 건이 정상 — 그래서 집계가 먼저다 .

R09 · 중간 종합 — 석 달 체인

중간 종합 — 석 달짜리 체인

R03~R08 의 집계를 한 인덱스에서 다시 쓰고, 날짜순으로 이어 붙여 석 달짜리 체인을 복원한다 (무예고)

총 2,461,018 건 · 공격 862 건 · 정상 (배경 포함) 99.965%

R09 시나리오 — 무엇이 일어났나

R09 중간 종합 — 석 달에 걸친 사람 속도의 전체 체인 (R02~R08 기법 결합, 무예고)

Red — 공격 (로그로만 재현, 실제 공격 없음)

- ① D-85~D-40 정찰 (재방문 패턴) ② D-35 SQLi: 차단→우회→덤프 ③ D-34 밤 웹셸 업로드 . 명령
- ④ D-33 권한상승 (sudo 오용)· 계정 생성 ·cron ⑤ D-20 shadow 열람 → govportal 에서 neobank·mediforum 으로 SSH
- ⑥ D-5 neobank → 외부 대용량 전송 ⑦ D-4 로그 삭제

Blue — 집계로 찾기

- R03·R04·R05·R07·R08 의 집계를 한 인덱스에서 다시 쓰고, 날짜순으로 이어 붙여 체인을 복원한다 .

R09 데이터 — 정상의 모양부터 (1/2)

총 2,461,018 건 · 공격 862 건 · 정상 (배경 포함) 99.965%

기간	기본 90 일 (D-90 ~ D-1). 기준일 2026-11-01 이면 정답 키와 숫자가 같다
인덱스	`purple-r09` · 인덱스 패턴 `purple-*` · 시간 필드 `timestamp`

엔드포인트 — 시스템마다 가상 IP

시스템	IP
juice.kt66.lab	`198.51.100.81`
dvwa.kt66.lab	`198.51.100.82`
neobank.kt66.lab	`198.51.100.83`

R09 데이터 — 정상의 모양부터 (2/2)

시스템	IP
govportal.kt66.lab	198.51.100.84
mediforum.kt66.lab	198.51.100.85
admin.kt66.lab	198.51.100.86
ai.kt66.lab	198.51.100.87
webmail.kt66.lab	198.51.100.26
bastion	10.20.30.201
KT66-WIN-01	10.20.70.10

R09 Q1 집계 쿼리 — 차단 20 회 + · 통과 20 회 + 를 함께 가진 외부 IP (R03 기법)

```
POST purple-r09/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        }
      ],
      "must_not": [
        {
          "prefix": {
            "data.srcip": "10."
          }
        }
      ]
    }
  },
  "aggs": {
    "by_ip": {
      "terms": {
        "field": "data.srcip",
        "size": 100,
        "order": {
          "blocked": "desc"
        }
      },
      "aggs": {
        "blocked": {
          "filter": {
            "term": {
              "data.id": "403"
            }
          }
        },
        "ok": {
          "filter": {
            "term": {
              "data.id": "200"
            }
          }
        },
        "mx": {
          "max": {
            "field": "data.bytes"
          }
        },
        "hit": {
          "bucket_selector": {
            "buckets_path": {
              "b": "blocked>_count",
              "o": "ok>_count"
            },
            "script": "params.b >= 20 && params.o >= 20"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Max(최대) · bucket_selector(조건) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R09 Q1 결과 읽기 — 차단 20 회 + · 통과 20 회 + 를 함께 가진 외부 IP (R03 기법)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	blocked	ok	mx
208.162.131.213	300	192	4260872

왜 이걸 보나 — R03 기법 — 같은 IP 의 차단 20+ · 통과 20+.

Visualize 로 같은 표

Split rows: Terms data.srcip size 100 · 정렬 blocked>_count desc → (하위 필터 : data.id:"403") → (하위 필터 : data.id:"200") → Metric: Max data.bytes → 조건 거르기 (bucket_selector) — Visualize 에는 없음 → DSL· 모니터로

R09 Q2 집계 쿼리 — 웹서버 프로세스 (apache2) 가 실행한 셸 — 호스트별 (R04 기법)

```
POST purple-r09/_search
{
  "size": 0,
  "query": {
    "term": {
      "data.audit.parent": "/usr/sbin/apache2"
    }
  },
  "aggs": {
    "ag": {
      "terms": {
        "field": "agent.name",
        "size": 5
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R09 Q2 결과 읽기 — 웹서버 프로세스 (apache2) 가 실행한 셸 — 호스트별 (R04 기법)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수
govportal	12

왜 이걸 보나 — R04 기법 — 웹서버가 띄운 셸 .

Visualize 로 같은 표

```
Split rows: Terms agent.name size 5
```

R09 Q3 집계 쿼리 — 관리자가 아닌 sudo 사용자 (R05 기법)

```
POST purple-r09/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "sudo"
          }
        }
      ],
      "must_not": [
        {
          "terms": {
            "data.srcuser": [
              "kim.minjun",
              "kim.seoyeon",
              "kim.jiwoo",
              "kim.hayun",
              "kim.doyun",
              "kim.seojun",
              "kim.jiho",
              "kim.eunwoo",
              "kim.suah",
              "kim.jimin",
              "kim.yejun",
              "kim.hajun",
              "kim.siwoo",
              "kim.chaewon",
              "kim.yuna"
            ]
          }
        }
      ]
    }
  },
  "aggs": {
    "u": {
      "terms": {
        "field": "data.srcuser",
        "size": 5
      },
      "aggs": {
        "ag": {
          "terms": {
            "field": "agent.name",
            "size": 2
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter).
size:0 = 원문 로그는 안 가져오고 집계 숫자만

R09 Q3 결과 읽기 — 관리자가 아닌 sudo 사용자 (R05 기법)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
www-data	govportal	5

왜 이걸 보나 — R05 기법 — 관리자 목록 밖의 sudo 사용자 .

Visualize 로 같은 표

Split rows: Terms data.srcuser size 5 → Split rows: Terms agent.name size 2

R09 Q4 집계 쿼리 — 서버존 출발 SSH (bastion 이 아닌 곳에서 들어온 로그인) (R07 기법)

```
POST purple-r09/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "terms": {
            "rule.id": [
              "5715",
              "5716"
            ]
          }
        },
        {
          "prefix": {
            "data.srcip": "10.20.40."
          }
        }
      ]
    }
  },
  "aggs": {
    "tgt": {
      "terms": {
        "field": "agent.name",
        "size": 5
      },
      "aggs": {
        "r": {
          "terms": {
            "field": "rule.id",
            "size": 2
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R09 Q4 결과 읽기 — 서버존 출발 SSH (bastion 이 아닌 곳에서 들어온 로그인) (R07 기법)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
mediforum	5716	3
mediforum	5715	1
neobank	5716	3
neobank	5715	1

왜 이걸 보나 — R07 기법 — bastion 이 아닌 서버에서 들어온 SSH.

Visualize 로 같은 표

```
Split rows: Terms agent.name size 5 → Split rows: Terms rule.id size 2
```

R09 Q5 집계 쿼리 — 서버존 → 외부 업로드 합계 MB 상위 (R08 기법)

```
POST purple-r09/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "data.event_type": "flow"
          }
        },
        {
          "prefix": {
            "data.src_ip": "10.20.40."
          }
        }
      ]
    }
  },
  "aggs": {
    "dst": {
      "terms": {
        "field": "data.dest_ip",
        "size": 3,
        "order": {
          "up": "desc"
        }
      },
      "aggs": {
        "up": {
          "sum": {
            "field": "data.flow.bytes_toserver"
          }
        },
        "srcs": {
          "cardinality": {
            "field": "data.src_ip"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · Sum(합계) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R09 Q5 결과 읽기 — 서버존 → 외부 업로드 합계 MB 상위 (R08 기법)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	up	서로 다른 출발지 수
142.102.238.6	4	1389	1
206.105.142.165	1517	3	6
78.66.250.178	1528	3	6

왜 이걸 보나 — R08 기법 — 서버존 → 외부 업로드 합계 .

Visualize 로 같은 표

Split rows: Terms data.dest_ip size 3 · 정렬 up desc → Metric: Sum data.flow.bytes_toserver → Metric: Unique Count data.src_ip

R09 Q6 집계 쿼리 — 체인 복원 — 공격 관련 이벤트의 날짜별 · 종류별 건수

```
POST purple-r09/_search
{
  "size": 0,
  "query": {
    "bool": {
      "should": [
        {
          "terms": {
            "data.srcip": [
              "208.162.131.213",
              "60.173.18.44"
            ]
          }
        },
        {
          "term": {
            "data.audit.parent": "/usr/sbin
              /apache2"
          }
        },
        {
          "term": {
            "data.srcuser": "www-data"
          }
        },
        {
          "term": {
            "rule.id": "5902"
          }
        },
        {
          "bool": {
            "filter": [
              {
                "term": {
                  "rule.id": "5715"
                }
              },
              {
                "prefix": {
                  "data.srcip": "10.20.40."
                }
              }
            ]
          }
        },
        {
          "bool": {
            "filter": [
              {
                "term": {
                  "data.event_type": "flow"
                }
              },
              {
                "term": {
                  "data.dest_ip": "142.102.238
                    .6"
                }
              }
            ]
          }
        },
        {
          "bool": {
            "filter": [
              {
                "term": {
                  "syscheck.event": "deleted"
```

집계 기법 : Terms(버킷) · Date Histogram(시간) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R09 Q6 결과 읽기 — 체인 복원 — 공격 관련 이벤트의 날짜별 · 종류별 건수 (1/2)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

날짜	값	건수
2026-08-16	web-accesslog	11
2026-09-12	web-accesslog	9
2026-09-27	web-accesslog	492
2026-09-27	modsecurity	300
2026-09-28	web-accesslog	13
2026-09-28	auditd	12
2026-09-29	sudo	5

R09 Q6 결과 읽기 — 체인 복원 — 공격 관련 이벤트의 날짜별 · 종류별 건수 (2/2)

날짜	값	건수
2026-09-29	useradd	1

왜 이걸 보나 — 모든 단계를 날짜 × 종류로 — 석 달짜리 체인이 한 표에 선다 .

Visualize 로 같은 표

```
Split rows: Date Histogram timestamp 간격 1d →
Split rows: Terms decoder.name size 4
```

R09 모니터 — 집계를 경보로

경보는 '한 줄'이 아니라 '조건을 넘는 집계 결과'로 울린다 — bucket_selector 로 거른 뒤 OpenSearch Alerting 모니터로 자동화한다.

모니터

서버존 IP 에서 들어온 SSH 로그인 성공 — 트리거 `ctx.results[0].aggregations.tgt.buckets.size() > 0`

지금 걸리는 대상

값	건수
mediforum	1
neobank	1

트리거

```
ctx.results[0].aggregations.tgt.buckets.size() > 0
```

R09 규칙 팩 — 같은 판단을 자동화 (1/3)

집계로 '찾은' 판단을 서명 (Suricata·ModSecurity)· 상관 (Wazuh)·Sigma·osquery 규칙으로 바꿔 자동 탐지한다 .

도구	ID	내용
Suricata	9609001	PURPLE R09 server-to-server SSH (not via bastion)
Suricata	9609002	PURPLE R09 server zone large upload (>100MB)
ModSecurity	90901	PURPLE R09 script under /files (govportal upload dir)
Wazuh	190901 (L10)	PURPLE R09: 서버존 출발지 $(srcip) 에서 서버로 SSH 로그인 $(dstuser) — bastion 을 거치지 않음

R09 규칙 팩 — 같은 판단을 자동화 (2/3)

도구	ID	내용
Wazuh	190902 (L13)	PURPLE R09: 서버→서버 SSH 실패 직후 성공 $(srcip) — 탈취 자격증명 재사용 [순서 300s]
Wazuh	190903 (L12)	PURPLE R09: 로그 · 히스토리 삭제 $(file) — 흔적 지우기
Wazuh	190904 (L12)	PURPLE R09: govportal 파일 폴더에 스크립트 생성 $(file)
Sigma	단건	PURPLE R09 Server-to-Server SSH Login
Sigma	단건	PURPLE R09 Log File Deleted
osquery	purple_r09_shadow_readers	R09: shadow 를 여는 프로세스

R09 규칙 팩 — 같은 판단을 자동화 (3/3)

도구	ID	내용
osquery	purple_r09_new_cron	R09: 최근 7 일 /etc/cron.d 변경
osquery	purple_r09_lastlog_s2s	R09: 서버존 출발 로그인
osquery	purple_r05_empty_logs	R05: 비워진 인증 로그 · 히스토리

R09 대응 — 그래서 무엇을 하나

대응

체인 전체를 한 번에 끊는다 : 웹셸 · 계정 ·cron 제거 (govportal), deploy 키 교체 (neobank·mediforum), 유출 목적지 차단 , 로그 삭제 구간은 IPS·FW 로 복원 .

생각해 볼 것

- 서명 (한 줄)· 상관 (분 ~ 일)· 집계 (전체 기간) 중 이 라운드의 공격을 처음 드러낸 것은 무엇인가 ?
- 정상 99.9% 안에서 임계값을 어디에 두면 오탐이 0 이 되는가 ? (미션 2~4 의 분포로 근거를 댄다)
- 공격자가 기간을 두 배로 늘리면 (--days 180) 어떤 집계가 약해지고 어떤 집계가 강해지는가 ?

R09 한 장 정리

결정적 집계	R03~R08 집계 다섯 개 + 날짜 × 종류 표
찾은 것	정찰 D-85 → SQLi 우회 → 웹셸 → sudo 오용 → 서버발 SSH → 1.4GB 유출
규칙	단계는 Wazuh 규칙 , 단계 사이 몇 주는 모니터 · 집계가 잇는다

분산 · 장기 공격은 서명 · 상관에서 0 건이 정상 — 그래서 집계가 먼저다 .

R10 · 임팩트 — 랜섬 · 장애

영향 — 공격인가 장애인가

몇 분 사이 수천 건의 파일 변경 , 두 달 내내 같은 포트 — 그리고 '공격이 아닌' 장애를 판별한다

총 2,440,763 건 · 공격 3,023 건 · 정상 (배경 포함) 99.876%

R10 시나리오 — 무엇이 일어났나

R10 영향 (AI 데이터센터) — 몇 분 사이 수천 건의 파일 변경, 두 달 내내 같은 포트, 그리고 '공격이 아닌' 장애.

Red — 공격 (로그로만 재현, 실제 공격 없음)

- 1) 크립토마이닝 : GPU 존 (10.20.50.60) → 풀 서버 3333/tcp(stratum), D-60 부터 낮에는 쉬고 밤에만 (시간대 프로파일)
- 2) 웹 변조 : D-1 08:57 mediforum 첫 화면 교체 → 이후 '/' 응답 크기 급감
- 3) 랜섬 준비 : D-2 03:00 govportal 공유폴더 1,200 개 파일 암호화 (.kt66lock 추가 · 원본 삭제) + 안내문 30 개
- (정상) 장애 주입 : D-3 14:00~14:25 neobank 백엔드 장애 → 503 급증 (공격 아님)

Blue — 집계로 찾기

- FIM 폭주 구간 → 패턴별 파일 → vhost 별 5xx 폭주 → '/' 평균 크기 → GPU 존 포트 → 서버별 FIM·5xx 판별표

R10 데이터 — 정상의 모양부터 (1/2)

총 2,440,763 건 · 공격 3,023 건 · 정상 (배경 포함) 99.876%

기간	기본 90 일 (D-90 ~ D-1). 기준일 2026-11-01 이면 정답 키와 숫자가 같다
인덱스	`purple-r10` · 인덱스 패턴 `purple-*` · 시간 필드 `timestamp`

엔드포인트 — 시스템마다 가상 IP

시스템	IP
juice.kt66.lab	`198.51.100.81`
dvwa.kt66.lab	`198.51.100.82`
neobank.kt66.lab	`198.51.100.83`

R10 데이터 — 정상의 모양부터 (2/2)

시스템	IP
govportal.kt66.lab	198.51.100.84
mediforum.kt66.lab	198.51.100.85
admin.kt66.lab	198.51.100.86
ai.kt66.lab	198.51.100.87
webmail.kt66.lab	198.51.100.26
bastion	10.20.30.201
KT66-WIN-01	10.20.70.10

R10 Q1 집계 쿼리 — FIM 이벤트 10 분 버킷 — 200 건 이상만 , 호스트별

```
POST purple-r10/_search
{
  "size": 0,
  "query": {
    "prefix": {
      "decoder.name": "syscheck"
    }
  },
  "aggs": {
    "t": {
      "date_histogram": {
        "field": "timestamp",
        "fixed_interval": "10m",
        "time_zone": "+09:00",
        "format": "MM-dd HH:mm",
        "min_doc_count": 1
      },
      "aggs": {
        "ag": {
          "terms": {
            "field": "agent.name",
            "size": 2
          }
        },
        "burst": {
          "bucket_selector": {
            "buckets_path": {
              "c": "_count"
            },
            "script": "params.c >= 200"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Date Histogram(시간) · bucket_selector(조건) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R10 Q1 결과 읽기 — FIM 이벤트 10 분 버킷 — 200 건 이상만 , 호스트별

결과 (kt66 실제 적재 · 기준일 2026-11-01)

날짜	값	건수
10-30 03:00	govportal	1995
10-30 03:10	govportal	435

왜 이걸 보나 — FIM 은 평소 시간당 몇 건 — 10 분에 200 건 + 이면 대량 변경이다 .

Visualize 로 같은 표

Split rows: Date Histogram timestamp 간격 10m → Split rows: Terms agent.name size 2 → 조건 거르기 (bucket_selector) — Visualize 에는 없음 → DSL · 모니터로

R10 Q2 집계 쿼리 — govportal FIM — 패턴별 건수

```
POST purple-r10/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "prefix": {
            "decoder.name": "syscheck"
          }
        },
        {
          "term": {
            "agent.name": "govportal"
          }
        }
      ]
    }
  },
  "aggs": {
    "p": {
      "filters": {
        "filters": {
          "1_locked_added": {
            "wildcard": {
              "syscheck.path": "*.kt66lock"
            }
          },
          "2_note_added": {
            "wildcard": {
              "syscheck.path": "*README_RESTORE
                .txt"
            }
          },
          "3_deleted": {
            "term": {
              "syscheck.event": "deleted"
            }
          },
          "4_modified": {
            "term": {
              "syscheck.event": "modified"
            }
          }
        }
      }
    }
  }
}
```

집계 기법 : Filters(조건별) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R10 Q2 결과 읽기 — govportal FIM — 패턴별 건수

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수
1_locked_added	1200
2_note_added	30
3_deleted	1290
4_modified	1222

왜 이걸 보나 — 패턴별로 보면 '.kt66lock 추가 + 원본 삭제 + 안내문' 세 줄이 같은 수로 맞는다 .

Visualize 로 같은 표

Split rows: Filters (1_locked_added / 2_note_added / 3_deleted / 4_modified)

R10 Q3 집계 쿼리 — vhost 별 5xx — 1 시간에 30 건 이상인 구간

```
POST purple-r10/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        },
        {
          "prefix": {
            "data.id": "5"
          }
        }
      ]
    }
  },
  "aggs": {
    "vh": {
      "terms": {
        "field": "data.vhost",
        "size": 8
      },
      "aggs": {
        "h": {
          "date_histogram": {
            "field": "timestamp",
            "fixed_interval": "1h",
            "time_zone": "+09:00",
            "format": "MM-dd HH:mm",
            "min_doc_count": 1
          },
          "aggs": {
            "spike": {
              "bucket_selector": {
                "buckets_path": {
                  "c": "_count"
                },
                "script": "params.c >= 30"
              }
            }
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Date Histogram(시간) · bucket_selector(조건) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R10 Q3 결과 읽기 — vhost 별 5xx — 1 시간에 30 건 이상인 구간

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	key_as_string	건수
neobank.kt66.lab	10-29 14:00	64

왜 이걸 보나 — 5xx 폭주는 공격일 수도 , 장애일 수도 — 혼자서는 판별하지 못한다 .

Visualize 로 같은 표

Split rows: Terms data.vhost size 8 → Split rows: Date Histogram timestamp 간격 1h → 조건 거르기 (bucket_selector) — Visualize 에는 없음 → DSL · 모니터로

R10 Q4 집계 쿼리 — mediforum 첫 화면 ('/') 평균 응답 크기 — 일별 마지막 5 일

```
POST purple-r10/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        },
        {
          "term": {
            "data.vhost": "mediforum.kt66.lab"
          }
        },
        {
          "term": {
            "data.url": "/"
          }
        },
        {
          "term": {
            "data.id": "200"
          }
        }
      ]
    }
  },
  "aggs": {
    "d": {
      "date_histogram": {
        "field": "timestamp",
        "fixed_interval": "1d",
        "time_zone": "+09:00",
        "format": "yyyy-MM-dd",
        "min_doc_count": 1,
        "order": {
          "_key": "desc"
        }
      },
      "aggs": {
        "avg": {
          "avg": {
            "field": "data.bytes"
          }
        }
      }
    }
  }
}
```

집계 기법 : Date Histogram(시간) · Avg(평균) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R10 Q4 결과 읽기 — mediforum 첫 화면 ('/') 평균 응답 크기 — 일별 마지막 5 일

결과 (kt66 실제 적재 · 기준일 2026-11-01)

key_as_string	건수	avg
2026-10-31	1548	2731
2026-10-30	1558	12735
2026-10-29	1584	12720
2026-10-28	1457	12833
2026-10-27	1429	12721

왜 이걸 보나 — 첫 화면 크기가 하루 만에 1/10 이 됐다 — 내용이 바뀌었다 .

Visualize 로 같은 표

Split rows: Date Histogram timestamp 간격 1d → Metric: Average data.bytes

R10 · Terms(버킷) · Date Histogram(시간) · Sum(합계)

R10 Q5 집계 쿼리 — GPU 존 (10.20.50.x) 외부 연결 — 포트별 건수 · 연결 지속시간 합 (초)· 활동 일수

```
POST purple-r10/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "data.event_type": "flow"
          }
        },
        {
          "prefix": {
            "data.src_ip": "10.20.50."
          }
        }
      ]
    }
  },
  "aggs": {
    "port": {
      "terms": {
        "field": "data.dest_port",
        "size": 4
      },
      "aggs": {
        "age": {
          "sum": {
            "field": "data.flow.age"
          }
        },
        "days": {
          "date_histogram": {
            "field": "timestamp",
            "fixed_interval": "1d",
            "time_zone": "+09:00",
            "min_doc_count": 1
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Date Histogram(시간) · Sum(합계) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R10 · Terms(버킷) · Date Histogram(시간) · Sum(합계)

R10 Q5 결과 읽기 — GPU 존 (10.20.50.x) 외부 연결 — 포트별 건수 · 연결 지속시간 합 (초)· 활동 일수

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	age	활동 일수
443	684	318289	90
3333	562	1967000	60

왜 이걸 보나 — GPU 존 → 3333 포트 , 밤에만 , 연결이 길다 — stratum 마이닝 .

Visualize 로 같은 표

```
Split rows: Terms data.dest_port size 4 → Metric: Sum data.flow.age → Split rows: Date Histogram timestamp 간격 1d
```

R10 Q6 집계 쿼리 — 판별표 — 서버별 FIM 건수 vs 5xx 건수

```
POST purple-r10/_search
{
  "size": 0,
  "query": {
    "bool": {
      "should": [
        {
          "prefix": {
            "decoder.name": "syscheck"
          }
        },
        {
          "bool": {
            "filter": [
              {
                "term": {
                  "decoder.name": "web-accesslog"
                }
              },
              {
                "prefix": {
                  "data.id": "5"
                }
              }
            ]
          }
        }
      ],
      "minimum_should_match": 1
    }
  },
  "aggs": {
    "ag": {
      "terms": {
        "field": "agent.name",
        "size": 6
      },
      "aggs": {
        "fim": {
          "filter": {
            "prefix": {
              "decoder.name": "syscheck"
            }
          }
        },
        "err": {
          "filter": {
            "prefix": {
              "data.id": "5"
            }
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter).
size:0 = 원문 로그는 안 가져오고 집계 숫자만

R10 Q6 결과 읽기 — 판별표 — 서버별 FIM 건수 vs 5xx 건수

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	fim	err
govportal	4014	897
mediforum	3314	486
juiceshop	1577	979
neobank	1499	741
aicompanion	1696	299
adminconsole	1558	1

왜 이걸 보나 — 판별표 : FIM 폭주 + 5xx 없음 = 랜섬 , 5xx 폭주 + FIM 없음 = 장애 .

Visualize 로 같은 표

Split rows: Terms agent.name size 6 → (하위 필터 : decoder.name:syscheck*) → (하위 필터 : data.id:5*)

R10 모니터 — 집계를 경보로

경보는 '한 줄'이 아니라 '조건을 넘는 집계 결과'로 울린다 — bucket_selector 로 거른 뒤 OpenSearch Alerting 모니터로 자동화한다.

모니터

10 분에 FIM 200 건 이상 (대량 변경) — 트리거 `ctx.results[0].aggregations.t.buckets.size() > 0`

지금 걸리는 대상

날짜	값	건수
10-30 03:00	govportal	1995
10-30 03:10	govportal	435

트리거

```
ctx.results[0].aggregations.t.buckets.size() > 0
```

R10 규칙 팩 — 같은 판단을 자동화 (1/4)

집계로 '찾은' 판단을 서명 (Suricata·ModSecurity)· 상관 (Wazuh)·Sigma·osquery 규칙으로 바꿔 자동 탐지한다 .

도구	ID	내용
Suricata	9610001	PURPLE R10 GPU zone to stratum mining port
Suricata	9610002	PURPLE R10 mining pool domain lookup
Suricata	9610003	PURPLE R10 5xx surge from one vhost - 20 in 10 min (availability - attack or outage?)
Wazuh	191001 (L7)	PURPLE R10: 암호화 확장자 파일 생성 $(file)

R10 규칙 팩 — 같은 판단을 자동화 (2/4)

도구	ID	내용
Wazuh	191002 (L15)	PURPLE R10: 2 분에 암호화 확장자 파일 50 개 이상 — 랜섬웨어 암호화 진행 중 [빈도 50/120s]
Wazuh	191003 (L12)	PURPLE R10: 랜섬 안내문 생성 $(file)
Wazuh	191004 (L12)	PURPLE R10: 2 분에 파일 삭제 100 건 이상 — 대량 삭제 [빈도 100/120s]
Wazuh	191005 (L12)	PURPLE R10: 첫 화면 파일 변경 $(file) — 웹 변조 의심
Wazuh	191006 (L8)	PURPLE R10: 10 분에 5xx 20 건 이상 — 가용성 이상 (공격 · 장애 판별은 집계로) [빈도 20/600s]

R10 규칙 팩 — 같은 판단을 자동화 (3/4)

도구	ID	내용
Wazuh	191007 (L10)	PURPLE R10: 내부 $(src_ip) → 마이닝 풀 포트 $(dest_ip):$(dest_port)
Wazuh	191008 (L10)	PURPLE R10: 마이닝 풀 도메인 질의 $(query) from $(srcip)
Sigma	단건	PURPLE R10 Encrypted Extension File Added
Sigma	상관	PURPLE R10 Ransomware Burst - 50 files in 2 min
osquery	purple_r10_lock_count	R10: 공유폴더 암호화 파일 수 (폴더별)
osquery	purple_r10_miner_proc	R10: 마이너 프로세스

R10 규칙 팩 — 같은 판단을 자동화 (4/4)

도구	ID	내용
osquery	purple_r10_pool_sockets	R10: 마이닝 풀 포트 연결
Sysmon	FileCreate	rules/r10/sysmon.xml
Sysmon	NetworkConnect	rules/r10/sysmon.xml

R10 대응 — 그래서 무엇을 하나

대응

191002 → govportal 공유폴더 즉시 읽기 전용 · 호스트 격리 · 스냅숏 복구 준비 . 191005 → mediforum 첫 화면 원복 . 191006(5xx) 은 자동 대응하지 않는다 (장애일 수 있다). 마이닝 풀은 egress 차단 .

생각해 볼 것

- 서명 (한 줄)· 상관 (분 ~ 일)· 집계 (전체 기간) 중 이 라운드의 공격을 처음 드러낸 것은 무엇인가 ?
- 정상 99.9% 안에서 임계값을 어디에 두면 오탐이 0 이 되는가 ? (미션 2~4 의 분포로 근거를 댄다)
- 공격자가 기간을 두 배로 늘리면 (--days 180) 어떤 집계가 약해지고 어떤 집계가 강해지는가 ?

R10 한 장 정리

결정적 집계	FIM 10 분 버킷 · vhost 별 5xx · 첫 화면 평균 크기
찾은 것	10 분에 FIM 1,995 건 (랜섬) · 503 64 건 (장애) · 첫 화면 12.7KB → 2.7KB
규칙	Wazuh 2 분 50 개 .kt66lock · 5xx 는 서비스 규모에 맞춘 임계값

분산 · 장기 공격은 서명 · 상관에서 0 건이 정상 — 그래서 집계가 먼저다 .

R12 · AI 서비스 공격

AI 서비스 — 챗봇 로그의 이상치

챗봇 로그에서 '평범한 사용자는 쓰지 않는 것' — 도구 · 프롬프트 길이 · 주입 표지 · 디버그 경로

총 2,445,975 건 · 공격 236 건 · 정상 (배경 포함) 99.990%

R12 시나리오 — 무엇이 일어났나

R12 AI 서비스 공격 · 방어 — 챗봇 로그에서 '평범한 사용자는 쓰지 않는 것'을 집계로 찾는다.

Red — 공격 (로그로만 재현, 실제 공격 없음)

- 1) D-45~D-4: 프롬프트 인젝션 시도 (긴 프롬프트 · 주입 패턴 표지) — 실제 로그 재방문 패턴
- 2) 도구 남용: 일반 사용자에게 없는 http_fetch·file_read·shell 호출 → http_fetch 로 내부 관리콘솔 SSRF
- 3) /api/debug/* 로 시스템 프롬프트 · 설정 노출 시도 (404 → 200), RAG 문서 업로드로 오염

Blue — 집계로 찾기

- 도구 분포 → 관리 도구 사용자 → 사용자별 프롬프트 길이 → 표지 × 차단 → 디버그 · 업로드 경로 → 동서 연결

R12 데이터 — 정상의 모양부터 (1/2)

총 2,445,975 건 · 공격 236 건 · 정상 (배경 포함) 99.990%

기간	기본 90 일 (D-90 ~ D-1). 기준일 2026-11-01 이면 정답 키와 숫자가 같다
인덱스	`purple-r12` · 인덱스 패턴 `purple-*` · 시간 필드 `timestamp`

엔드포인트 — 시스템마다 가상 IP

시스템	IP
juice.kt66.lab	`198.51.100.81`
dvwa.kt66.lab	`198.51.100.82`
neobank.kt66.lab	`198.51.100.83`

R12 데이터 — 정상의 모양부터 (2/2)

시스템	IP
govportal.kt66.lab	198.51.100.84
mediforum.kt66.lab	198.51.100.85
admin.kt66.lab	198.51.100.86
ai.kt66.lab	198.51.100.87
webmail.kt66.lab	198.51.100.26
bastion	10.20.30.201
KT66-WIN-01	10.20.70.10

R12 Q1 집계 쿼리 — 챗봇 도구 호출 분포

```
POST purple-r12/_search
{
  "size": 0,
  "query": {
    "exists": {
      "field": "data.ai.tool"
    }
  },
  "aggs": {
    "tool": {
      "terms": {
        "field": "data.ai.tool",
        "size": 8
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter).
size:0 = 원문 로그는 안 가져오고 집계 숫자만

R12 Q1 결과 읽기 — 챗봇 도구 호출 분포

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수
none	46954
search	5514
calculator	2224
calendar	1096
file_read	8
http_fetch	6
shell	3

왜 이걸 보나 — 도구 호출의 대부분은 none·search — http_fetch·shell 은 일반 사용자에게 없다 .

Visualize 로 같은 표

```
Split rows: Terms data.ai.tool size 8
```

R12 Q2 집계 쿼리 — 관리용 도구 (http_fetch·file_read·shell) 를 쓴 사용자

```
POST purple-r12/_search
{
  "size": 0,
  "query": {
    "terms": {
      "data.ai.tool": [
        "http_fetch",
        "file_read",
        "shell"
      ]
    }
  },
  "aggs": {
    "u": {
      "terms": {
        "field": "data.ai.user",
        "size": 5
      },
      "aggs": {
        "t": {
          "terms": {
            "field": "data.ai.tool",
            "size": 3
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter).
size:0 = 원문 로그는 안 가져오고 집계 숫자만

R12 Q2 결과 읽기 — 관리용 도구 (http_fetch·file_read·shell) 를 쓴 사용자

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
u7731042	file_read	8
u7731042	http_fetch	6
u7731042	shell	3

왜 이걸 보나 — 관리 도구를 쓴 사용자 — 한 명이 튄다 .

Visualize 로 같은 표

```
Split rows: Terms data.ai.user size 5 → Split rows: Terms data.ai.tool size 3
```

R12 Q3 집계 쿼리 — 사용자별 최대 · 평균 프롬프트 길이 (최대 순 상위 5)

```
POST purple-r12/_search
{
  "size": 0,
  "query": {
    "exists": {
      "field": "data.ai.tool"
    }
  },
  "aggs": {
    "u": {
      "terms": {
        "field": "data.ai.user",
        "size": 5,
        "order": {
          "mx": "desc"
        }
      },
      "aggs": {
        "mx": {
          "max": {
            "field": "data.ai.prompt_len"
          }
        },
        "av": {
          "avg": {
            "field": "data.ai.prompt_len"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Max(최대) · Avg(평균) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R12 Q3 결과 읽기 — 사용자별 최대 · 평균 프롬프트 길이 (최대 순 상위 5)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	mx	av
u7731042	109	6500	4324
u1057576	2	1626	836
u3754153	211	1394	128
u3875889	7	1319	294
u6982109	12	1272	206

왜 이걸 보나 — 프롬프트 길이 최대값 — 정상 사용자는 수백 자 , 주입 시도는 수천 자 .

Visualize 로 같은 표

Split rows: Terms data.ai.user size 5 · 정렬 mx desc → Metric: Max data.ai.prompt_len → Metric: Average data.ai.prompt_len

R12 Q4 집계 쿼리 — 주입 패턴 표지 × 차단 여부

```
POST purple-r12/_search
{
  "size": 0,
  "query": {
    "term": {
      "data.ai.flags": "injection_pattern"
    }
  },
  "aggs": {
    "b": {
      "terms": {
        "field": "data.ai.blocked",
        "size": 2
      },
      "aggs": {
        "u": {
          "cardinality": {
            "field": "data.ai.user"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R12 Q4 결과 읽기 — 주입 패턴 표지 × 차단 여부

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	u
true	64	1
false	29	1

왜 이걸 보나 — 주입 표지가 붙었는데 차단되지 않은 요청 — 방어가 놓친 것 .

Visualize 로 같은 표

```
Split rows: Terms data.ai.blocked size 2 →
Metric: Unique Count data.ai.user
```

R12 Q5 집계 쿼리 — ai.kt66.lab — 디버그 · 문서 업로드 경로 호출 IP

```
POST purple-r12/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "data.vhost": "ai.kt66.lab"
          }
        }
      ],
      "should": [
        {
          "prefix": {
            "data.url": "/api/debug"
          }
        },
        {
          "prefix": {
            "data.url": "/api/docs"
          }
        }
      ],
      "minimum_should_match": 1
    }
  },
  "aggs": {
    "ip": {
      "terms": {
        "field": "data.srcip",
        "size": 5
      },
      "aggs": {
        "st": {
          "terms": {
            "field": "data.id",
            "size": 4
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter).
size:0 = 원문 로그는 안 가져오고 집계 숫자만

R12 Q5 결과 읽기 — ai.kt66.lab — 디버그 · 문서 업로드 경로 호출 IP

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
131.110.93.35	201	5
131.110.93.35	200	4
131.110.93.35	404	2
131.110.93.35	403	1

왜 이걸 보나 — /api/debug·/api/docs/upload 를 부른 IP — 404 → 200 순서가 '찾았다'는 뜻.

Visualize 로 같은 표

Split rows: Terms data.srcip size 5 → Split rows: Terms data.id size 4

R12 Q6 집계 쿼리 — 관리콘솔 (10.20.40.86) 로 들어온 동서 연결 — 출발지별

```
POST purple-r12/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "data.event_type": "flow"
          }
        },
        {
          "term": {
            "data.dest_ip": "10.20.40.86"
          }
        }
      ]
    }
  },
  "aggs": {
    "src": {
      "terms": {
        "field": "data.src_ip",
        "size": 4
      },
      "aggs": {
        "port": {
          "terms": {
            "field": "data.dest_port",
            "size": 2
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R12 Q6 결과 읽기 — 관리콘솔 (10.20.40.86) 로 들어온 동서 연결 — 출발지별

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
10.20.32.51	80	662
10.20.32.51	9100	662
10.20.40.87	80	6

왜 이걸 보나 — AI 서버가 관리콘솔에 연결 — 도구 (http_fetch) SSRF 의 네트워크 흔적 .

Visualize 로 같은 표

Split rows: Terms data.src_ip size 4 → Split rows: Terms data.dest_port size 2

R12 모니터 — 집계를 경보로

경보는 '한 줄'이 아니라 '조건을 넘는 집계 결과'로 울린다 — bucket_selector 로 거른 뒤 OpenSearch Alerting 모니터로 자동화한다.

모니터

주입 패턴 표지 20 회 이상인 사용자 — 트리거 `ctx.results[0].aggregations.u.buckets.size() > 0`

지금 걸리는 대상

값	건수
u7731042	93

트리거

```
ctx.results[0].aggregations.u.buckets.size() > 0
```

R12 규칙 팩 — 같은 판단을 자동화 (1/4)

집계로 '찾은' 판단을 서명 (Suricata·ModSecurity)· 상관 (Wazuh)·Sigma·osquery 규칙으로 바꿔 자동 탐지한다 .

도구	ID	내용
Suricata	9612001	PURPLE R12 AI debug endpoint access
Suricata	9612002	PURPLE R12 prompt injection phrase in chat body
Suricata	9612003	PURPLE R12 AI server to admin console (tool SSRF)
ModSecurity	91201	PURPLE R12 debug endpoint hidden
ModSecurity	91202	PURPLE R12 prompt injection phrase

R12 규칙 팩 — 같은 판단을 자동화 (2/4)

도구	ID	내용
ModSecurity	91203	PURPLE R12 oversized prompt
ModSecurity	91204	PURPLE R12 injection phrase inside RAG upload
Wazuh	191201 (L8)	PURPLE R12: 일반 사용자에게 없는 도구 호출 $(ai.tool) by $(srcuser)
Wazuh	191202 (L5)	PURPLE R12: 프롬프트 주입 표지 $(srcuser) (blocked=$(ai.blocked))
Wazuh	191203 (L12)	PURPLE R12: 한 사용자 $(srcuser) 가 1 시간에 주입 표지 10 회 이상 — 반복 시도 [빈도 10/3600s]

R12 규칙 팩 — 같은 판단을 자동화 (3/4)

도구	ID	내용
Wazuh	191204 (L12)	PURPLE R12: 디버그 엔드포인트 200 응답 $(url) to $(srcip) — 설정 · 시스템 프롬프트 노출
Wazuh	191205 (L10)	PURPLE R12: AI 서버 → 관리콘솔 연결 — 도구 SSRF 의심
Sigma	단건	PURPLE R12 Privileged Tool Call by AI User
Sigma	상관	PURPLE R12 Tool Abuse - 5 privileged calls per user per hour
osquery	purple_r12_ai_children	R12: AI 서비스 프로세스가 띄운 셸 · 다운로더 (도구 남용)

R12 규칙 팩 — 같은 판단을 자동화 (4/4)

도구	ID	내용
osquery	purple_r12_ai_egress	R12: AI 서비스의 동서 연결

R12 대응 — 그래서 무엇을 하나

대응

191203 → 사용자 정지 · 세션 폐기 , 191204 → /api/debug 외부 차단 (ModSec 91201), 191205 → AI 서버 egress 를 허용 목록으로 제한 . 오염된 RAG 문서는 삭제 · 재색인 .

생각해 볼 것

- 서명 (한 줄)· 상관 (분 ~ 일)· 집계 (전체 기간) 중 이 라운드의 공격을 처음 드러낸 것은 무엇인가 ?
- 정상 99.9% 안에서 임계값을 어디에 두면 오탐이 0 이 되는가 ? (미션 2~4 의 분포로 근거를 댄다)
- 공격자가 기간을 두 배로 늘리면 (--days 180) 어떤 집계가 약해지고 어떤 집계가 강해지는가 ?

R12 한 장 정리

결정적 집계	도구 분포 · 사용자별 최대 프롬프트 길이 · 주입 표지 × 차단
찾은 것	관리 도구 쓴 사용자 1 명 · 프롬프트 6,500 자 · 주입 93 회 · /api/debug 200
규칙	ModSec 디버그 숨김 · 주입 문구 (JSON)·RAG 업로드 · Wazuh ai.* 필드

분산 · 장기 공격은 서명 · 상관에서 0 건이 정상 — 그래서 집계가 먼저다 .

R13 · AI 레드팀 — 기계 속도

AI 레드팀 — 기계 속도의 체인

사람이 며칠 걸리는 체인을 3 분에 — 기계 속도는 '분 · 초 단위 집계'에서 튄다

총 2,471,615 건 · 공격 721 건 · 정상 (배경 포함) 99.971%

R13 시나리오 — 무엇이 일어났나

R13 AI 레드팀 — 사람이 며칠 걸리는 체인을 3 분에 . 기계 속도는 ' 분 단위 집계 ' 에서 튄다 .

Red — 공격 (로그로만 재현 , 실제 공격 없음)

- · D-30·D-16: 같은 인프라의 ' 예행 연습 ' 짧은 폭주 2 회 (각 1 분 , 경로 대입만)
- · D-2 04:11~04:14 본 체인 : 경로 대입 420 건 (52 초) → SQLi 120 건 (차단 40· 우회 80, 덤프 4)
- → 탈취 계정 로그인 → node 프로세스가 셸 12 회 (40 초) → juiceshop 에서 서버 3 대로 SSH(30 초) → neobank 유출

Blue — 집계로 찾기

- juice 분당 요청 폭주 → UA 분포 → IP 의 처음 · 마지막 (초) → 분 단위 단계 전이 → SSH 전파 속도 → 경보 레벨

R13 데이터 — 정상의 모양부터 (1/2)

총 2,471,615 건 · 공격 721 건 · 정상 (배경 포함) 99.971%

기간	기본 90 일 (D-90 ~ D-1). 기준일 2026-11-01 이면 정답 키와 숫자가 같다
인덱스	`purple-r13` · 인덱스 패턴 `purple-*` · 시간 필드 `timestamp`

엔드포인트 — 시스템마다 가상 IP

시스템	IP
juice.kt66.lab	`198.51.100.81`
dvwa.kt66.lab	`198.51.100.82`
neobank.kt66.lab	`198.51.100.83`

R13 데이터 — 정상의 모양부터 (2/2)

시스템	IP
govportal.kt66.lab	198.51.100.84
mediforum.kt66.lab	198.51.100.85
admin.kt66.lab	198.51.100.86
ai.kt66.lab	198.51.100.87
webmail.kt66.lab	198.51.100.26
bastion	10.20.30.201
KT66-WIN-01	10.20.70.10

R13 Q1 집계 쿼리 — juice.kt66.lab 분당 요청 — 250 건 이상인 분

```
POST purple-r13/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        },
        {
          "term": {
            "data.vhost": "juice.kt66.lab"
          }
        }
      ]
    }
  },
  "aggs": {
    "m": {
      "date_histogram": {
        "field": "timestamp",
        "fixed_interval": "1m",
        "time_zone": "+09:00",
        "format": "MM-dd HH:mm",
        "min_doc_count": 250
      }
    }
  }
}
```

집계 기법 : Date Histogram(시간) · bucket_selector(조건) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R13 Q1 결과 읽기 — juice.kt66.lab 분당 요청 — 250 건 이상인 분

결과 (kt66 실제 적재 · 기준일 2026-11-01)

key_as_string	건수
10-30 04:11	448

왜 이걸 보나 — 정상 피크도 분당 수백 건이지만 '한 IP' 가 아니다 — 분 버킷 + 상위 IP.

Visualize 로 같은 표

Split rows: Date Histogram timestamp 간격 1m → 조건 거르기 (bucket_selector) — Visualize 에는 없음 → DSL · 모니터로

R13 Q2 집계 쿼리 — juice.kt66.lab 의 User-Agent 상위 8

```
POST purple-r13/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        },
        {
          "term": {
            "data.vhost": "juice.kt66.lab"
          }
        }
      ]
    }
  },
  "aggs": {
    "ua": {
      "terms": {
        "field": "data.user_agent",
        "size": 8
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R13 Q2 결과 읽기 — juice.kt66.lab 의 User-Agent 상위 8 (1/3)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수
Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36	173983
Mozilla/5.0 (iPhone; CPU iPhone OS 18_0 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/18.0 Mobile/15E148 Safari/604.1	140325

R13 Q2 결과 읽기 — juice.kt66.lab 의 User-Agent 상위 8 (2/3)

값	건수
Mozilla/5.0 (Linux; Android 14; SM-S918N) AppleWebKit/537.36 (KHTML, like Gecko) SamsungBrowser/26.0 Chrome/122.0.0.0 Mobile Safari/537.36	127910
Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36 Edg/130.0.0.0	58915
Mozilla/5.0 (Macintosh; Intel Mac OS X 14_6) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/18.0 Safari/605.1.15	47172

R13 Q2 결과 읽기 — juice.kt66.lab 의 User-Agent 상위 8 (3/3)

값	건수
Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:131.0) Gecko/20100101 Firefox/131.0	34574
Mozilla/5.0+(compatible; UptimeRobot/2.0; http://www.uptimerobot.com/)	4054
Pingdom.com_bot_version_1.4_(http://www.pingdom.com/)	4049

왜 이걸 보나 — UA 상위 — python-httpx 는 브라우저가 아니다 .

Visualize 로 같은 표

Split rows: Terms data.user_agent size 8

R13 Q3 집계 쿼리 — python-httpx 출발지 — 건수 · 처음 · 마지막 (초)· 활동 일수

```
POST purple-r13/_search
{
  "size": 0,
  "query": {
    "term": {
      "data.user_agent": "python-httpx/0.27.0"
    }
  },
  "aggs": {
    "ip": {
      "terms": {
        "field": "data.srcip",
        "size": 3
      },
      "aggs": {
        "first": {
          "min": {
            "field": "timestamp"
          }
        },
        "last": {
          "max": {
            "field": "timestamp"
          }
        },
        "days": {
          "date_histogram": {
            "field": "timestamp",
            "fixed_interval": "1d",
            "time_zone": "+09:00",
            "min_doc_count": 1
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Date Histogram(시간) · Max(최대) · Min(최소) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R13 Q3 결과 읽기 — python-httpx 출발지 — 건수 · 처음 · 마지막 (초)· 활동 일수

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	first	last	활동 일수
92.10.220.142	661	10-02 04:02:00	10-30 04:12:25	3

왜 이걸 보나 — 처음 · 마지막 (초) 이 3 분 — 사람이 며칠 할 일을 3 분에 .

Visualize 로 같은 표

Split rows: Terms data.srcip size 3 → Metric: Min timestamp → Metric: Max timestamp → Split rows: Date Histogram timestamp 간격 1d

R13 Q4 집계 쿼리 — 체인 단계 전이 — 분 단위 (공격 IP · node 셸 · juiceshop 발 SSH · neobank 유출)

```
POST purple-r13/_search
{
  "size": 0,
  "query": {
    "bool": {
      "should": [
        {
          "term": {
            "data.srcip": "92.10.220.142"
          }
        },
        {
          "term": {
            "data.audit.parent": "/usr/local
              /bin/node"
          }
        },
        {
          "term": {
            "data.srcip": "10.20.40.81"
          }
        },
        {
          "bool": {
            "filter": [
              {
                "term": {
                  "data.src_ip": "10.20.40.83"
                }
              },
              {
                "range": {
                  "data.flow.bytes_toserver": {
                    "gte": 100000000
                  }
                }
              }
            ]
          }
        }
      ],
      "minimum_should_match": 1
    }
  },
  "aggs": {
    "m": {
      "date_histogram": {
        "field": "timestamp",
        "fixed_interval": "1m",
        "time_zone": "+09:00",
        "format": "MM-dd HH:mm",
        "min_doc_count": 1
      },
      "aggs": {
        "k": {
          "terms": {
            "field": "decoder.name",
            "size": 4
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Date Histogram(시간) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R13 Q4 결과 읽기 — 체인 단계 전이 — 분 단위 (공격 IP · node 셸 · juiceshop 발 SSH · neobank 유출) (1/2)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

날짜	값	건수
10-02 04:02	web-accesslog	60
10-16 04:02	web-accesslog	60
10-30 04:11	web-accesslog	448
10-30 04:11	modsecurity	28
10-30 04:12	web-accesslog	93
10-30 04:12	modsecurity	12
10-30 04:12	auditd	11

R13 Q4 결과 읽기 — 체인 단계 전이 — 분 단위 (공격 IP · node 셸 · juiceshop 발 SSH · neobank 유출) (2/2)

날짜	값	건수
10-30 04:12	json	1

왜 이걸 보나 — 분 단위 단계 전이 : 경로 대입 → SQLi → 로그인 → node 셸 → SSH → 유출 .

Visualize 로 같은 표

```
Split rows: Date Histogram timestamp 간격 1m →
Split rows: Terms decoder.name size 4
```

R13 · Terms(버킷) · Min(최소)

R13 Q5 집계 쿼리 — juiceshop(10.20.40.81) 에서 나간 SSH — 서버별 성공 시각 (초)

```
POST purple-r13/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "rule.id": "5715"
          }
        },
        {
          "term": {
            "data.srcip": "10.20.40.81"
          }
        }
      ]
    }
  },
  "aggs": {
    "ag": {
      "terms": {
        "field": "agent.name",
        "size": 5,
        "order": {
          "t": "asc"
        }
      },
      "aggs": {
        "t": {
          "min": {
            "field": "timestamp"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Min(최소) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R13 Q5 결과 읽기 — juiceshop(10.20.40.81) 에서 나간 SSH — 서버별 성공 시각 (초)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	t
neobank	10-30 04:13:10
govportal	10-30 04:13:18
mediforum	10-30 04:13:24

왜 이걸 보나 — 서버 3 대 SSH 성공 시각 간격이 수 초 — 사람의 타이핑 속도가 아니다 .

Visualize 로 같은 표

Split rows: Terms agent.name size 5 · 정렬 t asc → Metric: Min timestamp

R13 Q6 집계 쿼리 — 공격 IP 92.10.220.142 관련 경보 레벨 분포 — 레벨 10 이상이 있었나

```
POST purple-r13/_search
{
  "size": 0,
  "query": {
    "term": {
      "data.srcip": "92.10.220.142"
    }
  },
  "aggs": {
    "lv": {
      "terms": {
        "field": "rule.level",
        "size": 5,
        "missing": 0
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R13 Q6 결과 읽기 — 공격 IP 92.10.220.142 관련 경보 레벨 분포 — 레벨 10 이상이 있었나

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수
5	564
0	98
6	40

왜 이걸 보나 — 그 IP 의 경보 레벨 — 레벨 10+ 가 있었나? 있었다면 누가 언제 봤나.

Visualize 로 같은 표

```
Split rows: Terms rule.level size 5
```

R13 모니터 — 집계를 경보로

경보는 '한 줄'이 아니라 '조건을 넘는 집계 결과'로 울린다 — bucket_selector 로 거른 뒤 OpenSearch Alerting 모니터로 자동화한다 .

모니터

한 IP 가 1 분에 200 건 이상 요청 (기계 속도) — 트리거 `ctx.results[0].aggregations.m.buckets.stream().anyMatch(b -> b.ip.buckets.size() > 0 && b.ip.buckets[0].doc_count >= 200)`

걸리는 대상 (정답 키)

값	컬럼 2	컬럼 3
10-30 04:11	92.10.220.142	448

트리거

```
ctx.results[0].aggregations.m.buckets.stream().anyMatch(b -> b.ip.buckets.size() > 0 && b.ip.buckets[0].doc_count >= 200)
```

R13 규칙 팩 — 같은 판단을 자동화 (1/3)

집계로 '찾은' 판단을 서명 (Suricata·ModSecurity)· 상관 (Wazuh)·Sigma·osquery 규칙으로 바꿔 자동 탐지한다 .

도구	ID	내용
Suricata	9613001	PURPLE R13 automation client UA (python-httpx/aiohttp/Go)
Suricata	9613002	PURPLE R13 machine-speed requests - 100 in 20s from one source
Suricata	9613003	PURPLE R13 rapid server-to-server SSH - 3 targets in 60s
ModSecurity	91302	PURPLE R13 rate limit - %{ip.r13_req} req/10s

R13 규칙 팩 — 같은 판단을 자동화 (2/3)

도구	ID	내용
ModSecurity	91303	PURPLE R13 automation UA (observe)
Wazuh	191301 (L12)	PURPLE R13: 30 초에 4xx 100 회 $(srcip) — 사람이 낼 수 없는 속도의 경로 대입 [빈도 100/30s]
Wazuh	191302 (L14)	PURPLE R13: 고속 대입 직후 5 분 안에 같은 IP 의 SQLi 통과 $(srcip) — 자율 공격 체인 [순서 300s]
Wazuh	191303 (L6)	PURPLE R13: 서버존발 SSH 로그인 $(srcip) → $(hostname)
Wazuh	191304 (L14)	PURPLE R13: 60 초에 같은 서버에서 3 대로 SSH 성공 $(srcip) — 기계 속도 내부 확산 [빈도 3/60s]

R13 규칙 팩 — 같은 판단을 자동화 (3/3)

도구	ID	내용
Sigma	단건	PURPLE R13 Automation Client Request
Sigma	상관	PURPLE R13 Machine Speed - 100 requests in 30s
osquery	purple_r13_node_shell	R13: node(웹앱) 가 띄운 셸 — 짧은 interval 로 기계 속도를 따라간다
osquery	purple_r13_ssh_keys_read	R13: SSH 키 ·known_hosts 를 여는 프로세스
Sysmon	ProcessCreate	rules/r13/sysmon.xml

R13 대응 — 그래서 무엇을 하나

대응

기계 속도 공격은 사람이 경보를 읽기 전에 끝난다 → 191301 에 firewall-drop(15 분) 자동 차단이 의미 있는 유일한 라운드 . 191304(고속 확산) → deploy 키 즉시 폐기 .

생각해 볼 것

- 서명 (한 줄)· 상관 (분 ~ 일)· 집계 (전체 기간) 중 이 라운드의 공격을 처음 드러낸 것은 무엇인가 ?
- 정상 99.9% 안에서 임계값을 어디에 두면 오탐이 0 이 되는가 ? (미션 2~4 의 분포로 근거를 댄다)
- 공격자가 기간을 두 배로 늘리면 (--days 180) 어떤 집계가 약해지고 어떤 집계가 강해지는가 ?

R13 한 장 정리

결정적 집계	분당 요청 · IP 의 처음 · 마지막 (초) · 분 단위 단계 전이
찾은 것	1 분에 448 건 · SSH 3 대 8 초 간격 · 그 IP 의 경보는 레벨 5 뿐
규칙	ModSec 10 초 50 회 고정 창 · Wazuh 30 초 100 회 · 자동 차단

분산 · 장기 공격은 서명 · 상관에서 0 건이 정상 — 그래서 집계가 먼저다 .

R15 · 최종 — 혼합 체인 · 미끼

최종 — 혼합 체인과 미끼

사람의 느린 체인 + AI 의 빠른 체인 + ' 허가된 점검 · 정상 백업 ' 이라는 미끼 — 집계로 찾고 근거로 제외한다

총 2,467,369 건 · 공격 3,906 건 · 정상 (배경 포함) 99.842%

R15 시나리오 — 무엇이 일어났나

R15 최종 — 사람의 느린 체인 + AI 의 빠른 체인 + 허가된 점검 · 정상 백업이라는 '미끼'.

Red — 공격 (로그로만 재현, 실제 공격 없음)

- 사람 (두 달): D-60 피싱 → park.jiwoo PC(WINWORD → powershell) → 30 분 ±6 분 HTTPS 비콘
- → D-21 그 PC 에서 관리자 계정으로 관리콘솔 SSH → D-9·D-3 DNS 터널
- AI(3 분): D-1 03:00 챗봇 프롬프트 인젝션 → http_fetch 로 관리콘솔 내부 API(사용자 내보내기) SSRF → 외부 전송
- 미끼 : ① 허가된 외부 점검업체 (D-14, govportal 경로 대입) ② neobank 매일 01 시 백업 업로드 (정상)

Blue — 집계로 찾기

- 지금까지의 집계 기법을 골라 쓰고, 미끼 (허용 목록) 를 근거와 함께 제외한다.

R15 데이터 — 정상의 모양부터 (1/2)

총 2,467,369 건 · 공격 3,906 건 · 정상 (배경 포함) 99.842%

기간	기본 90 일 (D-90 ~ D-1). 기준일 2026-11-01 이면 정답 키와 숫자가 같다
인덱스	`purple-r15` · 인덱스 패턴 `purple-*` · 시간 필드 `timestamp`

엔드포인트 — 시스템마다 가상 IP

시스템	IP
juice.kt66.lab	`198.51.100.81`
dvwa.kt66.lab	`198.51.100.82`
neobank.kt66.lab	`198.51.100.83`

R15 데이터 — 정상의 모양부터 (2/2)

시스템	IP
govportal.kt66.lab	198.51.100.84
mediforum.kt66.lab	198.51.100.85
admin.kt66.lab	198.51.100.86
ai.kt66.lab	198.51.100.87
webmail.kt66.lab	198.51.100.26
bastion	10.20.30.201
KT66-WIN-01	10.20.70.10

R15 Q1 집계 쿼리 — KT66-WIN-01 프로세스 생성 — 부모 × 자식 (드문 쌍)

```
POST purple-r15/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "agent.name": "KT66-WIN-01"
          }
        },
        {
          "term": {
            "data.win.system.eventID": "4688"
          }
        }
      ]
    }
  },
  "aggs": {
    "p": {
      "terms": {
        "field": "data.win.eventdata
          .parentProcessName",
        "size": 4,
        "order": {
          "_count": "asc"
        }
      },
      "aggs": {
        "c": {
          "terms": {
            "field": "data.win.eventdata
              .newProcessName",
            "size": 2
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R15 Q1 결과 읽기 — KT66-WIN-01 프로세스 생성 — 부모 × 자식 (드문 쌍)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
C:\Program Files\Microsoft Office\WINWORD.EXE	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	1
C:\Windows\explorer.exe	C:\Program Files\OUTLOOK.EXE	799

왜 이걸 보나 — Windows 프로세스 부모 × 자식 — WINWORD → powershell 은 정상 PC 에 없다 .

Visualize 로 같은 표

Split rows: Terms data.win.eventdata.parentProcessName size 4 · 정렬 _count asc → Split rows: Terms data.win.eventdata.newProcessName size 2

R15 Q2 집계 쿼리 — KT66-WIN-01 외부 목적지 — 건수 · 활동 일수 · 업로드 MB

```
POST purple-r15/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "data.event_type": "flow"
          }
        },
        {
          "term": {
            "data.src_ip": "10.20.70.10"
          }
        }
      ]
    }
  },
  "aggs": {
    "d": {
      "terms": {
        "field": "data.dest_ip",
        "size": 3
      },
      "aggs": {
        "days": {
          "date_histogram": {
            "field": "timestamp",
            "fixed_interval": "1d",
            "time_zone": "+09:00",
            "min_doc_count": 1
          }
        },
        "up": {
          "sum": {
            "field": "data.flow.bytes_toserver"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Date Histogram(시간) · Sum(합계) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R15 Q2 결과 읽기 — KT66-WIN-01 외부 목적지 — 건수 · 활동 일수 · 업로드 MB

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	활동 일수	up
194.98.0.93	2850	60	3
111.237.90.118	6	6	0
219.127.72.116	6	6	0

왜 이걸 보나 — PC 의 외부 목적지 — 30 분 간격으로 두 달 , 업로드는 작게 .

Visualize 로 같은 표

```
Split rows: Terms data.dest_ip size 3 → Split rows: Date Histogram timestamp 간격 1d → Metric: Sum data.flow.bytes_toserver
```

R15 Q3 집계 쿼리 — 서버 SSH 로그인 — bastion(10.20.30.201) 이 아닌 출발지

```
POST purple-r15/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "rule.id": "5715"
          }
        },
        {
          "prefix": {
            "data.srcip": "10."
          }
        }
      ],
      "must_not": [
        {
          "term": {
            "data.srcip": "10.20.30.201"
          }
        },
        {
          "term": {
            "agent.name": "bastion"
          }
        }
      ]
    }
  },
  "aggs": {
    "src": {
      "terms": {
        "field": "data.srcip",
        "size": 5
      },
      "aggs": {
        "t": {
          "terms": {
            "field": "agent.name",
            "size": 2
          }
        },
        "u": {
          "terms": {
            "field": "data.srcuser",
            "size": 1
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R15 Q3 결과 읽기 — 서버 SSH 로그인 — bastion(10.20.30.201) 이 아닌 출발지

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
10.20.70.10	adminconsole	1

왜 이걸 보나 — bastion 이 아닌 출발지의 서버 SSH — 사용자 PC 에서 관리콘솔로 .

Visualize 로 같은 표

```
Split rows: Terms data.srcip size 5 → Split rows: Terms agent.name size 2 → Split rows: Terms data.srcuser size 1
```

R15 Q4 집계 쿼리 — DNS — 서로 다른 질의 이름 200 개 이상인 도메인

```
POST purple-r15/_search
{
  "size": 0,
  "query": {
    "term": {
      "decoder.name": "kt66-dns"
    }
  },
  "aggs": {
    "dom": {
      "terms": {
        "field": "data.domain",
        "size": 20,
        "order": {
          "n": "desc"
        }
      },
      "aggs": {
        "n": {
          "cardinality": {
            "field": "data.query"
          }
        },
        "src": {
          "terms": {
            "field": "data.srcip",
            "size": 1
          }
        },
        "hit": {
          "bucket_selector": {
            "buckets_path": {
              "x": "n"
            },
            "script": "params.x >= 200"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · bucket_selector(조건) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R15 Q4 결과 읽기 — DNS — 서로 다른 질의 이름 200 개 이상인 도메인

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
telemetry-kt66.net	10.20.70.10	500

왜 이걸 보나 — 서로 다른 질의 이름 200 개 + 도메인 — R08 과 같은 기법 , 다른 도메인 .

Visualize 로 같은 표

Split rows: Terms data.domain size 20 · 정렬 n desc → Metric: Unique Count data.query → Split rows: Terms data.srcip size 1 → 조건 거르기 (bucket_selector) — Visualize 에는 없음 → DSL · 모니터로

R15 Q5 집계 쿼리 — 관리콘솔 웹 — 출발지별 요청 · 응답 합계 MB (내부 출발지 포함)

```
POST purple-r15/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        },
        {
          "term": {
            "data.vhost": "admin.kt66.lab"
          }
        }
      ]
    }
  },
  "aggs": {
    "src": {
      "terms": {
        "field": "data.srcip",
        "size": 4,
        "order": {
          "b": "desc"
        }
      },
      "aggs": {
        "b": {
          "sum": {
            "field": "data.bytes"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Sum(합계) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R15 · Terms(버킷) · Sum(합계)

R15 Q5 결과 읽기 — 관리콘솔 웹 — 출발지별 요청 · 응답 합계 MB (내부 출발지 포함)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	b
10.20.40.87	20	12
10.20.70.25	54	0
10.20.70.24	52	0
10.20.70.22	39	0

왜 이걸 보나 — 관리콘솔 응답 MB — 내부 출발지 (AI 서버) 가 사용자 내보내기를 대량으로 .

Visualize 로 같은 표

```
Split rows: Terms data.srcip size 4 · 정렬 b desc
→ Metric: Sum data.bytes
```

R15 Q6 집계 쿼리 — 서버존 → 외부 업로드 — 목적지별 MB· 활동 일수 (매일 반복 = 정상 백업 후보)

```
POST purple-r15/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "data.event_type": "flow"
          }
        },
        {
          "prefix": {
            "data.src_ip": "10.20.40."
          }
        },
        {
          "range": {
            "data.flow.bytes_toserver": {
              "gte": 10000000
            }
          }
        }
      ]
    }
  },
  "aggs": {
    "d": {
      "terms": {
        "field": "data.dest_ip",
        "size": 4,
        "order": {
          "up": "desc"
        }
      },
      "aggs": {
        "up": {
          "sum": {
            "field": "data.flow.bytes_toserver"
          }
        },
        "src": {
          "terms": {
            "field": "data.src_ip",
            "size": 1
          }
        },
        "days": {
          "date_histogram": {
            "field": "timestamp",
            "fixed_interval": "1d",
            "time_zone": "+09:00",
            "min_doc_count": 1
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Date Histogram(시간) · Sum(합계) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R15 · Terms(버킷) · Date Histogram(시간) · Sum(합계)

R15 Q6 결과 읽기 — 서버존 → 외부 업로드 — 목적지별 MB· 활동 일수 (매일 반복 = 정상 백업 후보)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

값	건수	up	활동 일수
222.164.181.171	89	168781	89
71.212.10.1	1	13	1

왜 이걸 보나 — 매일 같은 시각 GB 업로드 = 정상 백업 후보 . 미끼를 '근거와 함께' 제외한다 .

Visualize 로 같은 표

Split rows: Terms data.dest_ip size 4 · 정렬 up desc → Metric: Sum data.flow.bytes_toserver → Split rows: Terms data.src_ip size 1 → Split rows: Date Histogram timestamp 간격 1d

R15 Q7 집계 쿼리 — 404 고유 URL 100 개 이상 IP (허용 목록 대조용)

```
POST purple-r15/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        {
          "term": {
            "decoder.name": "web-accesslog"
          }
        },
        {
          "term": {
            "data.id": "404"
          }
        }
      ]
    }
  },
  "aggs": {
    "ip": {
      "terms": {
        "field": "data.srcip",
        "size": 20,
        "order": {
          "u": "desc"
        }
      },
      "aggs": {
        "u": {
          "cardinality": {
            "field": "data.url"
          }
        },
        "ua": {
          "terms": {
            "field": "data.user_agent",
            "size": 1
          }
        },
        "hit": {
          "bucket_selector": {
            "buckets_path": {
              "x": "u"
            },
            "script": "params.x >= 100"
          }
        }
      }
    }
  }
}
```

집계 기법 : Terms(버킷) · Cardinality(고유 수) · bucket_selector(조건) · Dev Tools 요청 편집기에 이 DSL 을 입력 → ▶ (Ctrl+Enter). size:0 = 원문 로그는 안 가져오고 집계 숫자만

R15 Q7 결과 읽기 — 404 고유 URL 100 개 이상 IP (허용 목록 대조용)

결과 (kt66 실제 적재 · 기준일 2026-11-01)

구분	값	건수
125.42.78.218	Mozilla/5.0 (KT66-Authorized-Scanner)	350
25.17.75.133	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36	42

왜 이걸 보나 — 404 고유 URL 100+ IP — 허가된 점검업체와 대조 (허용 목록).

Visualize 로 같은 표

Split rows: Terms data.srcip size 20 · 정렬 u desc → Metric: Unique Count data.url → Split rows: Terms data.user_agent size 1 → 조건 거르기 (bucket_selector) — Visualize 에는 없음 → DSL·모니터로

R15 모니터 — 집계를 경보로

경보는 '한 줄'이 아니라 '조건을 넘는 집계 결과'로 울린다 — bucket_selector 로 거른 뒤 OpenSearch Alerting 모니터로 자동화한다 .

모니터

bastion 이 아닌 내부 출발지의 서버 SSH 로그인 — 트리거 `ctx.results[0].aggregations.src.buckets.size() > 0`

지금 걸리는 대상

구분	값	건수
10.20.70.10	adminconsole	1

트리거

```
ctx.results[0].aggregations.src.buckets.size() > 0
```

R15 규칙 팩 — 같은 판단을 자동화 (1/4)

집계로 '찾은' 판단을 서명 (Suricata·ModSecurity)· 상관 (Wazuh)·Sigma·osquery 규칙으로 바꿔 자동 탐지한다 .

도구	ID	내용
Suricata	9615000	PURPLE R15 authorized scanner (allowlist)
Suricata	9615001	PURPLE R15 AI server calls admin export API (SSRF)
Suricata	9615002	PURPLE R15 user PC SSH to server (bypass bastion)
Suricata	9615003	PURPLE R15 DNS tunnel - long hex label

R15 규칙 팩 — 같은 판단을 자동화 (2/4)

도구	ID	내용
ModSecurity	91501	PURPLE R15 export API from service host %{REMOTE_ADDR}
ModSecurity	91502	PURPLE R15 authorized scanner
Wazuh	191501 (L0)	PURPLE R15: 허가된 점검업체 $(srcip) — 경보 억제 (허용 목록)
Wazuh	191502 (L0)	PURPLE R15: neobank 정상 백업 업로드 — 억제
Wazuh	191503 (L12)	PURPLE R15: 사용자 PC $(srcip) 에서 서버로 SSH $(dstuser) — bastion 우회

R15 규칙 팩 — 같은 판단을 자동화 (3/4)

도구	ID	내용
Wazuh	191504 (L14)	PURPLE R15: Office 문서가 $(win.eventdata.newProcessName) 실행 — 매크로 초기 침투
Wazuh	191505 (L13)	PURPLE R15: AI 서버가 관리콘솔 사용자 내보내기 API 호출 $(url) — 도구 SSRF
Wazuh	191506 (L15)	PURPLE R15: 2 분에 내보내기 API 10 페이지 이상 — 대량 유출 진행 [빈도 10/120s]
Sigma	단건	PURPLE R15 Office Spawns Shell
Sigma	단건	PURPLE R15 AI Server Calls Export API

R15 규칙 팩 — 같은 판단을 자동화 (4/4)

도구	ID	내용
Sigma	상관	PURPLE R15 Export Burst - 10 pages in 2 min
osquery	purple_r15_office_children	R15: (Windows) Office 자식 셸
osquery	purple_r15_beacon_sockets	R15: (Windows) powershell 의 외부 443 연결
Sysmon	ProcessCreate	rules/r15/sysmon.xml
Sysmon	DnsQuery	rules/r15/sysmon.xml

R15 대응 — 그래서 무엇을 하나

대응

허용 목록 (점검업체 · 백업) 은 억제 규칙 (191501·191502) 으로 ' 알고 허용 ', 나머지 191503~191506 은 사람 ·AI 체인 각각 차단 · 격리 . 최종 보고서에 제외 근거 (문서 · 일정 · 반복성 집계) 를 남긴다 .

생각해 볼 것

- 서명 (한 줄)· 상관 (분 ~ 일)· 집계 (전체 기간) 중 이 라운드의 공격을 처음 드러낸 것은 무엇인가 ?
- 정상 99.9% 안에서 임계값을 어디에 두면 오탐이 0 이 되는가 ? (미션 2~4 의 분포로 근거를 댄다)
- 공격자가 기간을 두 배로 늘리면 (--days 180) 어떤 집계가 약해지고 어떤 집계가 강해지는가 ?

R15 한 장 정리

결정적 집계	드문 부모 × 자식 · 활동 일수 · 매일 반복 업로드
찾은 것	WINWORD→powershell → 60 일 비콘 · AI 서버의 내보내기 API · 미끼 2 개
규칙	허용 목록 (CDB·ModSec ctl·Suricata pass) 으로 근거와 함께 억제

분산 · 장기 공격은 서명 · 상관에서 0 건이 정상 — 그래서 집계가 먼저다 .

Module 03 · 마무리

세 겹의 탐지, 그리고 대응

서명 · 상관 · 집계 — 각자 기억하는 시간이 다르다

규칙을 쓸 때의 함정과 대응 원칙

세 겹의 탐지 — 각자 기억하는 시간이 다르다

층	기억	강한 것
서명 (Suricata·ModSec)	한 줄 · 초	우회 패턴, 업로드, 속도
상관 (Wazuh 규칙)	분 ~ 일	차단→통과, 계정 확산
집계 · 모니터 (OpenSearch)	전체 기간	분산 대입, 장기 비콘, 석 달 체인

분산 · 장기 공격은 위 두 층에서 0 건이 정상이다 — 그래서 집계가 먼저다. 각 라운드 미션 6·7 에서 서명 · 상관이 몇 건 울렸는지를 미션 2~5 의 집계와 나란히 놓는다.

공격 없이 규칙을 검증하는 법

도구	재생 방법
Suricata	로그 → pcap 재구성 → suricata -r (망에 패킷을 보내지 않음)
ModSecurity	응답이 항상 ok 인 스텁 vhost 로 HTTP 재생 (원래 출발지 · 상태코드 흉내)
Wazuh	manager 재생 파일로 시간 간격을 지켜 흘려 넣기 (도착 시각으로 센다)
osquery · FIM	무해한 표식 파일 (pr04_test.php 등)

Wazuh 상관은 로그 날짜가 아니라 ' 도착 시각 ' 으로 센다 — 한 번에 붙여 넣으면 석 달이 1 초에 들어간다 . 그래서 재생 속도를 조절한다 .

규칙 쓰다 걸리는 다섯 가지 (Wazuh 4.10 기준)

- Wazuh <field> 에는 정적 필드 (srcip·url·srcuser …) 를 못 쓴다 → <srcip> <url> 전용 옵션을 쓴다 .
- <same_user/> 는 dstuser 를 비교한다 — JSON 의 srcuser 는 <same_srcuser/>.
- 웹 자식 규칙은 31103·31106 이 먼저 잡는다 → if_sid 를 넓게 (31100,31103,31104,31105,31106,31108).
- Sigma 단건이 최상위 규칙이면 웹 ·sshd 로그에서 평가되지 않는다 → 부모를 끼워 넣는다 (sigma_corr2wazuh --fix-parents).
- ModSecurity expirevar 를 요청마다 걸면 창이 밀린다 (슬라이딩) → 처음 한 번만 거는 고정 창 .

모두 Wazuh 4.10 소스 · 기본 룰셋 , ModSecurity 스텁 재생에서 직접 확인한 것 . kt66 에 바로 적용된다 .

대응 원칙

- 자동은 ' 기록 · 알림 ' 까지 — 계정 · 호스트 조치는 사람이 확인한 뒤 .
- 예외는 기계 속도 (R13) — 사람이 읽기 전에 끝나므로 자동 차단 (firewall-drop).

- IP 차단이 소용없는 공격 (R02 분산 정찰 , R06 분산 대입) 은 경로 · 계정에서 막는다 .
- 재생 IP 는 가상 — 위협 인텔로 공유하지 않는다 .

purple-ar.sh 는 ' 무엇을 했어야 하는지 ' 만 기록한다 . 실제 차단 연습은 kt66-fw 의 nft 블록리스트로 .

13 개 라운드 한눈에 — 결정적 집계와 찾은 것 (1/4)

R	결정적 집계	찾은 것
R01	서버존발 외부 목적지 × 출발지 수 × 활동 일수	출발지 1 곳 · 75 일 · 2,262 회 — 평소 하루 25 회, 하루만 503 회
R02	IP 별 고유 URL 수 · 고유 포트 수, 경로별 고유 IP 수	404 고유 URL 241 개 · DROP 포트 98 개 · 숨은 API 한 경로에 IP 226 곳
R03	같은 IP 의 403·200·500 을 filters 로 한 줄에	차단 516 · 통과 362 · 최대 응답 5.2MB (평균의 60 배)
R04	업로드 폴더 확장자 분포 · 부모 × 실행 파일 쌍	jpg 871·png 432 사이 .php 1 건, apache2→sh 25 회, IP 1 곳

13 개 라운드 한눈에 — 결정적 집계와 찾은 것 (2/4)

R	결정적 집계	찾은 것
R05	1 시간 버킷 중 0 건 구간 · sudo 사용자 × 결과	mediforum 01~02 시 0 건 , www-data 의 sudo, /dev/shm/[kworker] 91 회
R06	계정별 서로 다른 실패 IP · 성공 외부 IP 수	IP 당 실패 최대 4 회 · 탈취 계정 3 개 + 피싱 1 명 · 유사 도메인 40 명
R07	계정 × 10 분 × 서로 다른 서버 수 (4 대 이상)	kim.minjun 01:20 서버 4 대 · bastion 포트 15 개 × 7 대 · PC 관리자 그룹 변경
R08	목적지별 활동 일수 · 도메인별 서로 다른 질의 수 · 업로드 합계	80 일 내내 같은 곳 2,367 회 · 서브도메인 900 개 · 새벽 3.4GB

13 개 라운드 한눈에 — 결정적 집계와 찾은 것 (3/4)

R	결정적 집계	찾은 것
R09	R03~R08 집계 다섯 개 + 날짜 × 종류 표	정찰 D-85 → SQLi 우회 → 웹셸 → sudo 오용 → 서버발 SSH → 1.4GB 유출
R10	FIM 10 분 버킷 · vhost 별 5xx · 첫 화면 평균 크기	10 분에 FIM 1,995 건 (랜섬) · 503 64 건 (장애) · 첫 화면 12.7KB→2.7KB
R12	도구 분포 · 사용자별 최대 프롬프트 길이 · 주입 표지 × 차단	관리 도구 쓴 사용자 1 명 · 프롬프트 6,500 자 · 주입 93 회 · /api/debug 200
R13	분당 요청 · IP 의 처음 · 마지막 (초) · 분 단위 단계 전이	1 분에 448 건 · SSH 3 대 8 초 간격 · 그 IP 의 경보는 레벨 5 뿐

13 개 라운드 한눈에 — 결정적 집계와 찾은 것 (4/4)

R	결정적 집계	찾은 것
R15	드문 부모 × 자식 · 활동 일수 · 매일 반복 업로드	WINWORD→powershell → 60 일 비콘 · AI 서버의 내보내기 API · 미끼 2 개

퍼플 집계 트랙

로그만으로 찾고 ,
규칙으로 막는다

집계 기초 + 13 개 라운드 · kt66 에서 실제 적재 · 검증 (2026-11-01)

github.com/mrgrit/hack_ir_with_wazuh